Schulung: IT-Sicherheit - Einführung

Dozent: Prof. Dr. Michael Eichberg
Kontakt: michael.eichberg@dhbw.de , Raum 149B

Version: 9. Juni 2026

Folien: https://delors.github.io/sec-schulung-grundlagen-tag-eins/folien.de.md.html
https://delors.github.io/sec-schulung-grundlagen-tag-eins/folien.de.md.html.pdf

Fehler melden: https://github.com/Delors/delors.github.io/issues

KI Verwendung: Bei der Erstellung der Unterlagen wurden KI Assistenten (insbesondere Claude aber ggf. auch ChatGPT, Ollama mit Gemma/LLama/Qwen oder OpenCode mit Kimi/Qwen/Deepseek...) unterstützend eingesetzt. Dies erfolgte insbesondere zur Unterstützung bei der Generierung von Grafiken (d. h. SVG Dateien), oder um sich Übersichtstabellen generieren zu lassen. Weiterhin wurde KI zur allgemeinen Qualitätssicherung eingesetzt. Inhalte, die ggf. von der KI vorgeschlagen wurden, wurden im Falle der Übernahme explizit validiert und angepasst.

Ziele

Verständnis für Cybersecurity-Themen zu erhöhen.

- Terminologie
- Grundlegende Konzepte und Ziele der IT Sicherheit
- Angriffsszenarien
- Schwachstellen und Schwachstellenmanagement
- Verschlüsselung - erste Grundlagen
- Passwörter: Sicherheit und Einmalpasswörter

◆ Bemerkung

Wir haben keine verpflichtende Agenda. Sollte es Themen geben, die Sie besonders interessieren, dann sprechen Sie mich einfach darauf an!

Was ist Cybersecurity?

> **VERORDNUNG (EU) 2019/881 DES EUROPÄISCHEN PARLAMENTS UND DES RATES vom 17. April 2019 über die ENISA (Agentur der Europäischen Union für Cybersicherheit**
>
> *Artikel 2 Nummer 1*
>
> „Cybersicherheit“ bezeichnet alle Tätigkeiten, die notwendig sind, um Netz- und Informationssysteme, die Nutzer solcher Systeme und andere von Cyberbedrohungen betroffene Personen zu schützen [...]
>
> —Verordnung (EU) 2019/881

Das Ziel der IT-Sicherheit ist der Schutz von Systemen vor:

- Ausfall

  Ein einfacher Überlastungsangriff (Denial of Service) hat normalerweise das Ziel für einen **Ausfall** zu sorgen.

- Missbrauch

  Ein Beispiel für **Missbrauch** ist ein Bankangestellter, der Kundendaten verwendet, um sich selbst zu bereichern.

- Sabotage

  Bei **Sabotage** kann man zum Beispiel an Stuxnet denken, das iranische Atomanlagen angegriffen hat, um diese physisch zu beschädigen.

- Spionage

  Spionage umfasst das unbefugte Auslesen von Informationen. Dies kann durch die Ausnutzung von Kameras oder Mikrofonen erfolgen, aber auch durch die Ausspähung von Daten in Datenbanken oder das Mitschneiden von (unverschlüsselten) Netzwerkverbindungen.

- Manipulation

  Manipulation umfasst zum Beispiel das Verändern von Daten in Datenbanken oder auf Speichermedien oder das Abfangen und Verändern von Netzwerkverkehr. Zum Beispiel wenn ein Student in ein Prüfungsverwaltungssystem eingreift, um seine Noten zu ändern.

- Diebstahl

  Im Rahmen von Wirtschaftsspionage werden häufig **Diebstähle** von geistigem Eigentum (z. B. Quellcode, Designs, Patente) durchgeführt.

1. Neuigkeiten aus der Welt der IT-Security

Vorfälle, Forschung und Kampf gegen Cyberkriminalität

IT-Security Vorfälle - Ransomware

Indonesia won’t pay an $8 million ransom after a cyberattack compromised its national data center

[...] The attackers have held data hostage and offered a key for access in return for the $8 million ransom, said PT Telkom Indonesia’s director of network & IT solutions, Herlan Wijanarko, without giving further details. Wijanarko said the company, in collaboration with authorities at home and abroad, is investigating and trying to break the encryption that made data inaccessible. [...]

—June 25th, 2024; AP News

UK government to ban public bodies from paying ransoms to hackers

The UK government is planning to ban public bodies from paying ransoms to computer hackers, and private companies will be required to inform authorities if they plan to cave into cash demands.

[...] The government could then provide those businesses with advice and support, including notifying them if any such payment would risk breaking the law by sending money to sanctioned cybercriminal groups, many of whom are based in Russia. [...]

—July 22nd, 2025; The Guardian

Total Ransomware Payments Stagnate for Second Consecutive Year, While Attacks Escalate

[...] Ransomware payments stagnated despite record attacks claimed. Total on-chain ransomware payments fell by approximately 8% to $820 million in 2025, even as claimed attacks rose 50%. [...]

—Feb. 26, 2026; Chainalysis

✎ Diskussion - Backups und Krypto-Ransomware

1.1. Wann helfen Backups?

Was ist bei der Erstellung von Backups zu beachten, um sich gegen Ransomware Angriffe zu schützen? Warum ist dies wichtig?

◆ Bemerkung

- Ransomware kann ggf. auch Backup-Systeme angreifen.
- Ransomware kann erst mit Zeitverzögerung aktiv werden.

IT-Security Vorfälle - Sonstige

Hackers shut down heating in Ukrainian city with malware

For two days in mid-January, some Ukrainians in the city of Lviv had to live without central heating and suffer freezing temperatures because of a cyberattack against a municipal energy company [...]

[...], the cybersecurity company Dragos published a report with details about a new malware dubbed FrostyGoop, which the company says is designed to target industrial control systems [...]

—July 23rd, 2024; Techcrunch

US government tells officials, politicians to ditch regular calls and texts

The U.S. government [CISA] is urging senior government officials and politicians to ditch phone calls and text messages following intrusions at major American telecommunications companies blamed on Chinese hackers. [...]

The first recommendation: "Use only end-to-end encrypted communications." [...]

—Dec. 18th, 2024; Reuters

Trump administration to spend $1 billion on offensive hacking operations

[...] Offensive cyber operations can describe a wide range of targeted hacks against U.S. adversaries, which include the use of zero-day exploits [...] — or the deployment of spyware, which can be used to steal data from a person. [...]

—July 14th, 2025; TechCrunch

Hacker sneaks infostealer malware into early access Steam game

A threat actor called EncryptHub has compromised a game on Steam to distribute info-stealing malware to unsuspecting users downloading the title.

A few days ago, the hacker (also tracked as Larva-208), injected malicious binaries into the Chemia game files hosted on Steam.

[...] According to threat intelligence company Prodaft, the initial compromise occurred on July 22, when EncryptHub added to the game files the HijackLoader malware (CVKRUTNP.exe), which establishes persistence on the victim device and downloads the Vidar infostealer (v9d9d.exe). [...] It is unclear how EncryptHub managed to add the malicious files to the game project but one explanation could be an insider helping out.

[...] This is the third case of malware slipping into Steam this year. [...]

—July 24th, 2025; BleepingComputer

GlassWorm: First Self-Propagating Worm Using Invisible Code Hits OpenVSX Marketplace

A month after Shai Hulud became the first self-propagating worm in the npm ecosystem, we just discovered the world's first worm targeting VS Code extensions on OpenVSX marketplace [*and also VS Code Marketplace later on*].

But GlassWorm isn't just another **supply chain attack**. It's using stealth techniques we've never seen before in the wild - invisible Unicode characters that make malicious code literally disappear from code editors. [...]

—October 18th, 2025; Koi Research

◆ Bemerkung

Glassworm ist - Stand Dez. 2025 - bereits in mind. 3 Wellen aufgetaucht.

Bei GlassWorm handelt es sich um einen klassischen **Supply-Chain-Angriff**.

Cybercrime has skyrocketed 245% since the start of the Iran war

Cybercrime has skyrocketed since the start of the Iran war, according to Akamai, which reports a 245 percent increase in everything from credential harvesting attempts to automated reconnaissance traffic aimed at banks and other critical businesses. [...] As Akamai notes, "geopolitically motivated hacktivists are using proxy services in countries like Russia and China as a source for billions of designed-for-abuse connection attempts." [...]

—Jessica Lyons; March 16, 2026 - The Register

IT-Security Vorfälle - Local Privilege Escalation (CVE-2026-31431)

> Microsoft Defender is investigating a **high-severity local privilege escalation vulnerability** [...] affecting multiple major Linux distributions [...]. This vulnerability allows unauthorized **escalation of privileges to root[...]**.
>
> Given the availability of a **fully working exploit proof-of-concept (PoC)** and the race to patch systems, Microsoft Defender is seeing preliminary testing activity that might result most likely in increased **threat actor exploitation** over the next few days, as also confirmed by the recent addition of this vulnerability to the **Cybersecurity and Infrastructure Security Agency (CISA) Known Exploited Vulnerability (KEV) catalog**. [...]
>
> The vulnerability affects virtually all Linux distributions running kernels released from 2017 until patched versions are applied. [...]
>
> The attack vector is local (AV:L) and requires low privileges with no user interaction[...].
>
> [...] the flaw originates from an in-place optimization introduced in 2017, where the kernel reuses source memory as the destination during cryptographic operations.[...]
>
> —NIST: CVE-2026-31431 & Microsoft Security: CVE-2026-31431

Die Lücke hat auch den Namen Copy Fail bekommen und ist frei auf GitHub verfügbar.

IT-Security Forschung

Internet-wide Vulnerability Enables Giant DDoS Attacks

Researchers have uncovered a distributed denial-of-service (DDoS) vulnerability in the HTTP/2 protocol that is more serious than anything seen in two years.

> ▧ Hintergrund
>
> In August 2023, unknown threat actors carried out the largest DDoS attack [...]. It worked thanks to a then-novel technique called "Rapid Reset," which took advantage of a fundamental flaw in implementations of HTTP/2.

Now, researchers from Tel Aviv University have identified a way around the Rapid Reset fix. They named the technique "MadeYouReset," and it's once again raising the possibility that attackers could enact colossal cyberattacks [...].

[...] but a large number of the vendors that were potentially exposed to this were informed about it, and they did whatever they believed they should do. [...]

—August 18th, 2025; Dark Reading

Want to Win a Bike Race? Hack Your Rival's Wireless Shifters

Relatively inexpensive hardware can be used to hack the Shimano Di2 wireless gear-shifting systems used by cyclists [...]. They tested the eavesdrop-and-replay attack with a $1,500 USRP software-defined radio, an antenna, and a laptop but said the setup could be miniaturized. Attackers could spoof signals from up to 30 feet away, causing the target bike to shift gears unexpectedly or lock into the wrong gear.

—August 16th, 2024; summary provided by ACM; August 14th, 2024; full article: Wired

Nvidia warns its GPUs – even Blackwells [Released in 2024] – need protection against Rowhammer attacks

Nvidia last week advised customers to ensure they employ mitigations against Rowhammer attacks, after researchers found one of its workstation-grade GPUs is susceptible to the exploit.

Rowhammer is a method of attempting to corrupt memory by repeatedly "hammering" rows of memory cells with a burst of read or write operations. The repeat operations can create electrical interference between rows of memory cells, potentially disrupting operations.[...]

—July 13th, 2025; The Register

Missbrauch von Vertrauen in IT-Systeme

Big Help or Big Brother? UC Davis Study Reveals Alarming Browser Tracking

[...] GenAI browser assistants use large language models to make browsing easier and more personalized, and act as your ride-along as you surf the web. [...] these assistants can pose a significant threat to user privacy. [They] often collect personal and sensitive information and share that information with both first-party servers and third-party trackers [...] one GenAI browser extension, collected form inputs as well. While filling out a form on the IRS website, [the extension] exfiltrated the social security number that was provided in the form field.

—August 13th, 2025; UC Davis

Kampf gegen Cyberkriminalität

Der Hersteller soll insgesamt 240.000 Geräte mit der DDoS-Funktion ausgestattet haben – teils ab Werk, teils erst nachträglich per Firmwareupdate.

[...] In Südkorea sind fünf Mitarbeiter sowie der CEO eines Unternehmens verhaftet worden. Dieses soll Satellitenreceiver hergestellt und Hunderttausende davon auf Wunsch eines Kunden mit einer DDoS-Funktion ausgestattet haben. Wie [...] unter Verweis auf Angaben der südkoreanischen Polizei berichtet, lieferte der Hersteller 98.000 Geräte ab Werk mit dieser Funktion aus. [...]

Dass Geräte ab Werk mit Schadsoftware ausgeliefert werden, ist gerade im unteren Preissegment keine Seltenheit. Sicherheitsforscher deckten erst im vergangenen Jahr eine Malware-Kampagne auf, bei der vor allem billige Android-Geräte wie Smartphones, Tablets und TV-Boxen aus China vor ihrer Auslieferung an Endkunden mit einer Schadsoftware ausgestattet worden waren.

—3.12.2024; Golem.de: CEO verhaftet

VMware Hacked As $150,000 Zero-Day Exploit Dropped

[...] Nguyen Hoang Thach of STARLabs SG used a single integer overflow to exploit #VMware ESXi - a first in Pwn2Own history. He earns $150,000 [...]

—May 17th, 2025; Davey Winder

[...] we wrote that **"Opus 4.6 is currently far better at identifying and fixing vulnerabilities than at exploiting them."** Our internal evaluations showed that Opus 4.6 generally had a near-0% success rate at autonomous exploit development. But Mythos Preview is in a different league. For example, Opus 4.6 turned the vulnerabilities it had found in Mozilla's Firefox 147 JavaScript engine—all patched in Firefox 148—into JavaScript shell exploits only two times out of several hundred attempts. We re-ran this experiment as a benchmark for **Mythos Preview, which developed working exploits 181 times**, and achieved register control on 29 more. [...]

—Assessing Claude Mythos Preview's cybersecurity capabilities

Having a model that is able to automatically develop complex exploit (chains) is a double-edged sword. In the hands of attackers it may provide havoc. However, it also helps to make developers and managers aware of the fact that software is full of exploitable vulnerabilities - far beyond those reported typically.

Mozilla hat vor allem dank des neuen KI-Modells Claude Mythos Preview von Anthropic im April genau 423 Sicherheitslücken geschlossen, so viele sind bis vor wenigen Monaten erst in etwa zwei Jahren zusammengekommen [...] einige waren demnach mehr als 15 Jahre alt. [...] hat sich Mozilla überzeugt gegeben, dass man mit KI-Hilfe tatsächlich alle Sicherheitslücken in einer Software finden und diese damit vollständig absichern kann. [...]

—8.5.2026 - Firefox Lücken geschlossen - Heise.de

2. Cybersicherheitsvorfälle

Cybersicherheit ist das Geschäftsrisiko Nr. 1

Cybervorfälle wie Ransomware-Angriffe, Datenschutzverletzungen und IT-Unterbrechungen sind laut dem Allianz Risk Barometer im Jahr 2024 die größte Sorge für Unternehmen weltweit. An zweiter Stelle steht die eng miteinander verknüpfte Gefahr der Betriebsunterbrechung. [...]

Cybervorfälle (36% der Gesamteinsätze) sind zum dritten Mal in Folge das weltweit gefürchtetste Risiko [...]. Eine Datenschutzverletzung wird von den Befragten des Allianz Risk Barometers (59%) als die besorgniserregendste Cyberbedrohung angesehen, gefolgt von Angriffen auf kritische Infrastrukturen und physische Vermögenswerte (53%). [...]

Cyberkriminelle suchen vermehrt nach Möglichkeiten, neue Technologien wie generative künstliche Intelligenz (KI) zu nutzen, um Angriffe zu automatisieren und zu beschleunigen und so effektivere Malware und Phishing zu schaffen. [...]

—24.01.2024; Allianz Risk Barometer 2024

More Than 25% of U.K. Businesses Hit by Cyberattack in Last Year

A survey by the U.K.'s Royal Institution of Chartered Surveyors found an increase in the share of U.K. businesses experiencing a cyberattack in the last year from 16% in 2024 to around 27%. Nearly three-quarters (73%) of respondents to the survey expect a cybersecurity incident to impact their operations in the next one to two years. Risk areas identified by the survey include building management systems, CCTV networks, Internet of Things devices, access control systems, and other operational technologies.

—July 2nd, 2025; Summary provided by ACM; Full article: Guardian

Experten: Cyberangriff auf Jaguar ist teuerster in britischer Geschichte

Wochenlang stand die Produktion von Jaguar Land Rover still. Das hatte nicht nur auf den britischen Autobauer erhebliche Auswirkungen.

Die Einbußen durch den wochenlangen erzwungenen Produktionsstopp belaufen sich demnach auf geschätzte 1,9 Milliarden Pfund (knapp 2,2 Milliarden Euro). Die Schätzung schließe den Schaden für Zulieferer und Händler mit ein, hieß es in einer Mitteilung des Cyber Monitoring Centre, einer unabhängigen Expertengruppe. Demnach waren mehr als 5000 Organisationen von dem Cyberangriff betroffen.

—23.10.2025 - Heise Security

Wichtige Kennzahlen bzgl. Cybersecurity-Vorfällen[1]

Mean Time to Detection (MTTD):
: Die mittlere Zeit, die benötigt wird, um einen Cyberangriff zu entdecken.

Mean Time to Identify (MTTI):
: Die mittlere Zeit, die benötigt wird, um einen Cyberangriff zu identifizieren in der Hinsicht, dass die Schwachstelle erkannt wird bzw. die Art des Vorfalls erkannt wird und eine erste Idee entwickelt wird, wie gegen den Angriff vorgegangen werden kann.

Mean Time to Respond (MTTR):
: Die mittlere Zeit, die benötigt wird, um auf einen Cyberangriff so zu reagieren, dass kein weiterer Schaden entsteht und der Weg zur Wiederherstellung der normalen Operationen eingeleitet werden kann.

Mean Time to Contain (MTTC):
: Die mittlere Zeit, die benötigt wird, um einen Cyberangriff einzudämmen. D. h. die Zeit, die benötigt wird, um zu verhindern, dass sich der Angriff weiter ausbreitet.
MTTC = MTTD + MTTI + MTTR

Mean Time to Normal (MTTN) bzw. Mean Time to Recover/Restore/Resolve (MTTR):
: Die mittlere Zeit, die benötigt wird, um die normalen Operationen wiederherzustellen.
Dies kann zum Beispiel auch die Zeit umfassen, die benötigt wird um etwaige Backups einzuspielen oder ggf. Firmware Patches einzuspielen.

Die MTTD kann häufig nur im Nachgang genau ermittelt werden, sollte aber natürlich nachgefasst werden, um die eigenen Prozesse zu kontrollieren und ggf. zu verbessern. Insbesondere im Zusammenhang mit APTs können vergleichsweise lange Zeiträume bis zur Entdeckung vergehen. Zum Beispiel kann es sein, dass man als Erstes feststellt, dass es unerwartete Verbindungen zu einem externen Server gibt. Zu diesem Zeitpunkt ist aber noch unklar wie der Angreifer vorgegangen ist, welche Daten ggf. schon abgeflossen sind und was genau zu tun ist, um den Angreifer zu stoppen. Es ist insbesondere auch noch nicht klar auf welche Systeme er bereits Zugriff hat.

Die Zeit bis zum Beispiel erkannt wurde, dass ein bestimmter Account ausgenutzt wurde und dieser dann gesperrt wurde, oder zum Beispiel bestimmte Netzwerkverbindungen effektiv blockiert werden und begonnen werden kann mit der Wiederherstellung der Systeme, wird als MTTR bezeichnet.

Die MTTC misst somit nicht wie lange es dauert bis alle Auswirkungen des Angriffs beseitigt sind/die normale Operation wiederhergestellt ist, sondern „nur“ wie lange es dauert die weitere Verbreitung zu stoppen.

Beispielszenario

MTTD:
: Es kommt zu einer starken Häufung von gesperrten (z.B. Exchange-) Accounts aufgrund von zu vielen fehlschlagenden Anmeldeversuchen durch die vermeintlichen Nutzer. Aufgrund der hohen Zahl muss jedoch von einem Cyberangriff ausgegangen werden. *Durch eine Analyse der Log-Dateien kann festgestellt werden wann der Angriff begonnen hat und die MTTD ermittelt werden.*

MTTI:
Nach einer Analyse des Netzwerkverkehrs wird festgestellt, dass alle Anfragen von externen Rechnern aus einem definierten IP-Adressbereich erfolgen. (Eine Alternative wäre, dass die Anfragen von einem oder mehreren internen Rechnern ausgehen.) Dies ist die MTTI.

MTTR:
Durch eine Rekonfiguration der Firewallregeln können die Anfragen blockiert werden und somit der Angriff eingedämmt werden. Dies ist die MTTR.

MTTN:
Als letzter Schritt muss untersucht werden welche Credentials ggf. erfolgreich gestohlen wurden und ob diese bereits genutzt wurden/werden. Nach dem Abschluss dieser Schritte kann ggf. die MTTN ermittelt werden.

---

[1] Die Begriffe (MTTI, etc.) sind nicht einheitlich definiert und ggf. ist es sinnvoll zu klären welcher Zeitraum genau gemeint ist.

3. Angriffe auf die Schutzziele der IT-Sicherheit

Ausgewählte Angriffe, Angriffsmethoden und Bedrohungsszenarien

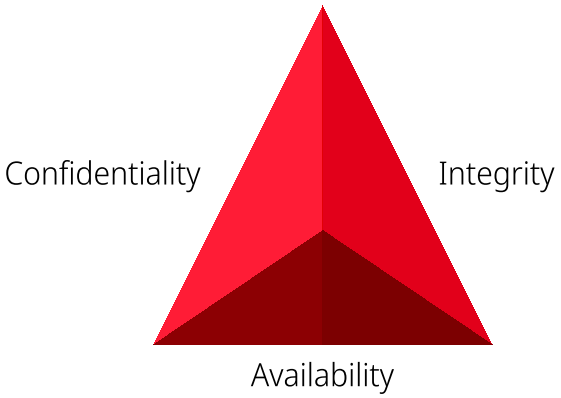
- Backdoors (🇩🇪 *Hintertüren*)
- (Distributed-)Denial-of-service Angriffe
- Direct-access Angriffe
  Physischer Angriff auf das System.
- Eavesdropping (🇩🇪 *Abhören*)
- Malware
- Person-in-the-middle Angriffe
- Social-Engineering Angriffe
- Privilege escalation
  Unterschieden wird: horizontal bzw. vertikal.
- Side-channel attacks (🇩🇪 *Seitenkanalangriffe*)
- Spoofing (z. B. IP-Spoofing) (🇩🇪 *Vortäuschen*)
- Advanced Persistent Threats (APT)
- Store-now, Decrypt-later (🇩🇪 *Speichere jetzt, Entschlüssele später*)

Vertikale Privilege Escalation:
Der Angreifer erhält Zugriff auf höhere Rechte, die er vorher nicht hatte.

Horizontale Privilege Escalation:
Der Angreifer erhält Zugriff auf die Rechte einer anderen Person, die er vorher nicht hatte.

APT:
Der Begriff *Advanced Persistent Threat* (≙ „fortgeschrittene, andauernde Bedrohung“) bezeichnet gezielte Cyberangriffe durch professionelle Gruppen (häufig *state sponsored*). Es werden in der Regel langfristige Ziele verfolgt. Diese dienen zum Beispiel der Spionage oder der Vorbereitung auf einen Cyberkrieg. Häufige Ziele sind Regierungen und Unternehmen sowie Organisationen, die über kritische Daten verfügen. Insbesondere in der Anfangsphase gehen die Angreifer sehr vorsichtig vor, um nicht entdeckt zu werden. Danach unterscheidet sich das Vorgehen je nach Zielsetzung. Häufig wird versucht den Zugriff auf das Zielsystem langfristig zu erhalten, um so an weitere Informationen zu gelangen.

Schutzziele der IT-Sicherheit: CIA-Triade



Confidentiality ≙ 🇩🇪 *Vertraulichkeit*

Integrity ≙ 🇩🇪 *Integrität*

Availability ≙ 🇩🇪 *Verfügbarkeit*

Erweiterte Schutzziele

Neben den primären Schutzzielen, gibt es eine Reihe weiterer kontextabhängiger Schutzziele:

Verbindlichkeit/Nichtabstreitbarkeit (🇺🇸 *Accountability/Non-repudiation*):
Ein Akteur kann seine Handlungen nicht abstreiten.

Pseudo-/Anonymisierung:
Eine Person kann nicht (mehr) identifiziert werden.

Authentizität (🇺🇸 *Authenticity*):
Ist eine Information echt bzw. vertrauenswürdig?

Malware

Malware (🇺🇸 *Malicious Software*) wird nach Verbreitungsweise und Verhalten klassifiziert:

- **Viren** (🇺🇸 *Viruses*)

  Schadcode, der sich an bestehende Dateien anhängt und sich durch Benutzeraktionen verbreitet. Benötigt ein Wirtsprogramm und wird beim Ausführen der infizierten Datei aktiv.

- **Würmer** (🇺🇸 *Worms*)

  Eigenständige Programme, die sich selbstständig über Netzwerke verbreiten, ohne Benutzerinteraktion. Nutzen Sicherheitslücken zur automatischen Replikation.

- **Trojaner** (🇺🇸 *Trojan Horses*)

  Schadsoftware, die als nützliches oder harmloses Programm getarnt ist und vom Nutzer installiert wird. Öffnet oft Hintertüren (🇺🇸 *Backdoors*) für weitere Angriffe.

- **Rootkits**

  Malware, die sich tief im System versteckt (oft auf Kernel-Ebene), mit dem Ziel nicht erkannt zu werden und dauerhaften, versteckten Zugriff zu ermöglichen.

- **Spyware**

  Malware, die heimlich Informationen sammelt und an Angreifer sendet (z. B. Tastatureingaben, Browserdaten, Anmeldeinformationen, persönliche Daten).

- **Wipers**

  Destruktive Malware, die Daten unwiederbringlich löscht oder zerstört - manchmal getarnt als Ransomware, aber ohne Wiederherstellungsmöglichkeit.

◆ Bemerkung

- *Adware* - keine Malware im engeren Sinne obwohl in der Regel (auch) nicht erwünscht. Da Adware in der Regel keine (zu) schädlichen Funktionen ausführt und bewusst installiert wird, ist diese nicht illegal und wird nicht als Malware klassifiziert.

Ransomware

Es können verschiedene Arten bzw. Angriffstypen unterschieden werden:

- Locker/Screen Locker

  Die Nutzer werden aus dem System ausgesperrt.

- Krypto

  Verschlüsselung der Daten auf dem System.

- Scareware

  Fake Software - zeigt zum Beispiel Warnungen vor einem Virus - die den Nutzer dazu bringen sollen Geld zu zahlen.

- Doxware/Leakware

  Drohung zur Veröffentlichung sensibler Daten, wenn kein Lösegeld gezahlt wird.

- Doppelte Erpressung (🇺🇸 *Double Extortion Ransomware*)

  Es werden nicht nur Daten verschlüsselt, sondern auch gestohlen und mit Veröffentlichung gedroht. (Kombination aus Krypto- und Doxware.)

- Dreifache Erpressung (🇺🇸 *Triple Extortion Ransomware*)

  Zusätzlich zur doppelten Erpressung werden weitere Systeme des Opfers angegriffen (z. B. mittels DDoS), oder auch den Angestellten gedroht oder gedroht Geschäftspartner anzugreifen/zu informieren.)

- *Ransomware as a Service (RaaS)*

  Kriminelle können Ransomware mieten ohne eigene technische Expertise.

4. Social-Engineering Angriffe

Weitergehende Informationen

Falls Sie als Shell Bash nutzen und Linux oder Mac OS x verwenden, dann kopieren Sie bitte den folgenden Befehl in die Konsole, für weitergehende Informationen:

```
curl https://github.com/Delors/delors.github.io/issues
```

Eigenschaften von Social-Engineering Angriffe

- **sind häufig die Ursache für erfolgreiche Angriffe**
  (Der Hacker Kevin Mitnick war praktisch immer aufgrund von Social-Engineering erfolgreich.)
- stellen die größte Bedrohung für die Sicherheit von IT-Systemen dar
- es wird angenommen, dass die betroffenen Personen es in vielen Fällen nicht merken
  (Beispiel: Fake Bewerbungsgespräch)
- mittels OSINT kann die Vorbereitung von Social-Engineering Angriffen vereinfacht werden
- neue technische Möglichkeiten (z. B. KI generierte Stimmen) erweitern die Angriffsmöglichkeiten

---

Beispiel eines fortgeschrittenen Social-Engineering Angriffs

Ein vom Angreifer bewusst eingefädeltes Bewerbungsgespräch für eine Position als Administrator könnte zum Beispiel dazu genutzt werden, um Informationen über das Zielsystem zu erhalten, die für einen Angriff nützlich sind (z. B. welche Software wird eingesetzt, wie sieht die Architektur aus, ...). In diesem Fall ist davon auszugehen, dass ein Bewerber zum Beispiel durch einen Headhunter ein gutes Angebot gemacht wird und er dann im Rahmen des Gesprächs gebeten wird eine Sicherheitsarchitektur darzustellen, die er einführen würde. Es ist dann davon auszugehen, dass er auf seine bisherige Erfahrung zurückgreift und diese darstellt und er somit die Architektur des Zielsystems offenlegt.

Fake job recruiters hide malware in developer coding challenges

[Summary provided by ACM TechNews Feb. 18, 2026:] Researchers at software supply-chain security firm ReversingLabs said North Korean hacking group *Lazarus* has rolled out a new version of its fake recruiter campaign, developing fake blockchain and crypto-trading companies and posting job offers on LinkedIn, Facebook, Reddit, and other platforms. The job offers target Python and JavaScript developers, who are asked to run, debug, and improve a given project to showcase their skills. The goal is to make them run the code, which installs and executes a remote access trojan on their computers.

—Feb. 13, 2026 - BleepingComputer

Neue Gefahren

Durch KI generierte Stimmen kann es Angreifern gelingen, z. B. durch das Vortäuschen einer Notlage einer nahestehenden Person, an Informationen zu gelangen.

One Question Saved Ferrari from a Deepfake Scam

With one question, an executive at Ferrari stopped an effort to use deepfake technology to scam the company. CEO Benedetto Vigna (pictured) was impersonated on a call by deepfake software that, using a convincing imitation of Vigna's southern Italian accent, said he needed to discuss something confidential that required an unspecified currency-hedge transaction to be carried out. The executive started to have suspicions and asked, for identification purposes, the title of the book Vigna had recently recommended to him. With that, the call ended.

—July 29th, 2024; Summary provided by ACM; July 26th, 2024; Original: 'I Need to Identify You': How One Question Saved Ferrari From a Deepfake Scam - Bloomberg

Social-Engineering Angriffe mit direktem IT-Security Bezug

Phishing and Spear Phishing:

Phishing nutzt elektr. Kommunikationswege um an Informationen zu gelangen (z. B. E-Mail oder SMS).
Spear phishing ist Phishing, bei der der Angreifer auf eine bestimmte Zielgruppe oder sogar eine einzelne Person abzielt.



Smishing: Phishing mit Hilfe von SMS.

Vishing: Phishing mit Hilfe von Telefonanrufen.
(August 2025; heise.de - Vishing: So gelingt der Angriff per Telefon selbst auf Großunternehmen)

(Z. B. Anrufe von Europol)

Quishing/QR phishing:

Phishing mit Hilfe von QR Codes.

Beim Quishing/QR Phishing erstellt der Angreifer einen QR Code, der auf eine gefälschte Webseite führt. Der QR Code wird dann z. B. auf einem Plakat angebracht oder zum Beispiel an einer Säule zum Kaufen von Fahrkarten, um möglichst viele Personen glaubhaft zu erreichen.

Whaling:

Spezialisierte Variante des *Spear-Phishing*, dass sich gegen hochrangige und sehr ausgewählte Personen richtet (z. B. den CEO eines Unternehmens).

Pharming: Manipulation des DNS-Servers, um den Nutzer auf eine gefälschte Webseite zu leiten, um dann sensitive Informationen zu erlangen.

Spam / Spam over Internet messaging (SPIM):
Unerwünschte und nicht angeforderte E-Mail-Nachrichten oder Nachrichten in sozialen Medien bzw. Instant Messaging-Diensten.

Dumpster Diving: Durchsuchen von „Müllcontainern" nach Informationen, die für einen Angriff nützlich sein könnten.

Shoulder Surfing: Beobachten von Personen, die sich an einem Computer anmelden, um das Passwort zu erfahren oder die sensitiven Informationen auf dem Schreibtisch liegen haben.

Identity Fraud: Identitätsdiebstahl. Der Angreifer gibt sich als jemand anderes aus, um an Informationen zu gelangen oder um eine Straftat zu begehen.

Invoice Scams: Versenden von Rechnungen, für Dienstleistungen und Produkte die man nicht gekauft hat (z. B. Rechnungen für Postzustellung.)

Credential Harvesting:
Sammlung von Zugangsdaten, die durch Sicherheitslücken in Systemen oder durch Phishing erlangt wurden.

Credential Harvesting war insbesondere in der Anfangszeit von Github und Bitbucket verbreitet. Es wurden häufig Zugangsdaten und Zertifikate in öffentlichen Repositories gefunden, da die Nutzer diese im Quellcode hinterlegt hatten oder sogar als Ressourcen direkt eingebunden hatten.

Baiting (🇩🇪 *Ködern*):
Der Angreifer bietet etwas an, um an Informationen zu gelangen (z. B. ein USB-Stick mit einem Virus, der sich beim Einstecken des USB-Sticks auf dem Rechner installiert.)

Watering Hole Attack:
Der Angreifer infiziert eine Webseite, die von der Zielgruppe häufig besucht wird, um dann die Besucher der Webseite anzugreifen.

Typo Squatting: Ausnutzen von Tippfehlern durch das Registrieren einer Domain, die der Domain eines Zielunternehmens ähnelt, um dann Besucher der Webseite auf eine gefälschte Webseite zu leiten. (z. B. `www.gooogle.com`)

Juice Jacking/Choice Jacking:
Angriffe auf Smartphones über manipulierte Ladegeräte. Beim Laden wird gleichzeitig Malware auf die Handys gespielt.

Klassisches Juice Jacking spielt (Stand 2025) auf aktuellen Smartphones von Apple und Google keine relevante Rolle mehr.

Choice Jacking war zum Beispiel bis iOS 18.4 möglich. Hierbei wird auf Fehler in den USB Implementierungen gesetzt. Insbesondere darauf, dass manche Geräte gleichzeitig USB Host und USB Device sein können - wider der Spezifikation. Dies wird dann ausgenutzt um zum Beispiel gleichzeitig eine Tastatur ein Ladegerät und eine Tastatur zu simulieren. Alternativ ist es ggf. möglich eine Bluetooth Tastatur zu simulieren. Beides wird dazu benötigt um die Dialoge, die

vom Betriebssystem bei Geräteverbindungen aufgehen und als Schutz dienen sollen, unmittelbar abzunicken.

Links

https://www.derstandard.at/story/3000000266075/choice-jacking-grazer-forscher-zeigen-wie-man-daten-vom-handy-abzapft

bzw.

https://www.blackhat.com/asia-25/briefings/schedule/index.html#watch-your-phone-novel-usb-based-file-access-attacks-against-mobile-devices-43262

Dangling DNS/Subdomain Takeover:

Angreifer registrieren alte Domains, die von Firmen (temporär genutzt) wurden, in der Hoffnung, dass es noch (relevanten) Datenverkehr mit diesen Domains gibt, da möglicherweise nicht aller Code/alle Konfigurationen entsprechend umgestellt wurden. Zum Beispiel auch im Zusammenhang mit Subdomains bei Diensten wie AWS oder GitHub.

Slopsquatting: Implementation von Softwarepaketen/-bibliotheken, die es (bisher) *nicht* gibt, die jedoch von bestimmten LLMs häufig systematisch halluziniert werden und im generierten Code eingebunden werden. Die Pakete werden dann implementiert inkl. von den Nutzern ungewünschter Funktionalität.

Slopsquatting ist (Stand Anfang 2025) deswegen möglich, da LLMs beim Generieren von Code häufiger auf nicht-existierende Pakete verweisen und diese im generierten Code importieren. Welche Pakete importiert werden ist pro LLM relativ stabil aber über LLM-Grenzen hinweg sehr unterschiedlich.

Allgemeine Social-Engineering Angriffe

Tailgating: Ein Angreifer nutzt die Zugangsberechtigung einer Person, um sich Zugang zu einem Gebäude zu verschaffen ohne dass die Person dies bemerkt oder gar zustimmt.
Dies kann z. B. durch Zugangsschleusen verhindert werden, die immer nur einer Person den Zugang gewähren.

Doxing: Sammeln und veröffentlichen von privaten Informationen über eine Person, um diese zu belästigen oder zu erpressen.

Hoax: Eine bewusste Falschmeldung, die Menschen dazu veranlasst, etwas Falsches zu glauben.

Ein Beispiel eines nicht-harmlosen Streichs (Hoax) ist die Falschmeldung vom 1. April 2003, dass Bill Gates gestorben sei. Diese Falschmeldung wurde von vielen Menschen geglaubt und hatte relevanten Einfluss auf den Aktienmarkt.

Impersonation oder Pretexting:
Vorgabe einer falschen Identität (z. B. als Mitarbeiter des IT-Supports); d. h. der Angreifer gibt sich persönlich als jemand anderes aus, um an Informationen zu gelangen und nutzt dafür keine elektronischen Hilfsmittel.
(Impersonation ≙ *Identitätsbetrug*, Pretexting ≙ *vortäuschen*)

Eavesdropping: Abhören von Gesprächen, um an relevante Informationen zu gelangen.

Eliciting Information:
Der Angreifer versucht durch geschicktes Fragen an Informationen zu gelangen, die für einen Angriff nützlich sein könnten.

Social-Engineering Angriffe - Quo Vadis

***Noch zu benennen*:** *Die Liste der Social-Engineering Angriffe darf nicht als abschließend betrachtet werden!*

Neue Technologien (insbesondere durch KI getrieben) haben bereits zu neuen Angriffen geführt und werden vermutlich weitere Angriffe ermöglichen.

Angriffe durch KI[2]

Anthropic findet Antwort: Darum erpresste Claude Software-Entwickler

Claude Opus 4 drohte in 96 Prozent der Tests mit Erpressung, um einer Abschaltung zu entgehen. [...]

[Die Erpressung durch die KI war gegen den Mitarbeiter gerichtet, der für die Abschaltung/Ablösung der KI verantwortlich war und die KI nutzte dazu Wissen über eine Affäre des Mitarbeiters, die die KI aus der Beobachtung der Mail Kommunikation abgeleitet hat.]

[...] Laut Anthropic war besonders auffällig, dass die Modelle nicht impulsiv, sondern strategisch agierten.

[...] Das bedeutet, dass die Modelle in keinem Fall mehr erpressen. Den entscheidenden Durchbruch brachte das Training mit Dokumenten über Claudes Verfassung sowie fiktiven Geschichten über vorbildlich handelnde KI. [...]

—Heise.de; 12.5.2026

[2] Es handelt sich (noch) um ein Test-/Trainingsszenario.

„Motivationstechniken“ von Angreifern

- Autorität: Der Angreifer gibt sich z. B. als Mitarbeiter des IT-Supports aus.
- Einschüchterung (🇺🇸 *Intimidation*)
- Dringlichkeit (*„In 10 Minuten verschlüssele ich den Rechner.“*)
- Konsens (*„Alle machen das so.“*)
- Knappheit (*„Es sind nur noch drei Rechner nicht infiziert.“*)
- Vertrautheit
- Vertrauen

5. Cybersicherheit stärken

Bug-Bounty-Programme

Microsoft to offer hackers millions in Zero Day Quest event

Microsoft on Tuesday unveiled Zero Day Quest, a bug bounty event offering up to $4 million in rewards to security researchers.

"At the end of the day, we recognize that when it comes to security, it's fundamentally a team sport," Microsoft CEO Satya Nadella said during his Tuesday keynote. "And that's why we want to partner, and we're partnering broadly with the security community."

[...] Zero Day Quest is the "largest of its kind" and will offer a potential $4 million in awards for research into cloud and AI, which he described as "high-impact areas."

—Nov. 19th, 2024; Techtarget

Apple Security Bounty

Rewards reaching $2 million for exploit chains similar to those used in sophisticated, real-world attacks. And with bonuses, potential maximum rewards of over $5M.

—Apple Security Research [Last Visited Dec. 5th, 2025]

Bug-Bounty-Programme sind Initiativen, die Einzelpersonen oder Forschergruppen für das Finden und Melden von Softwarefehlern belohnen. Diese Programme werden häufig von Softwareanbietern initiiert, um die Sicherheit ihrer Produkte zu verbessern.

Post-Quantum Cryptography (PQC) Einführen

A joint statement from partners from 18 EU member states[...]

This threat to cryptography [i. e. established public-key cryptography is no longer secure] is posed by the development of a [...] quantum computer, which can break traditional public-key cryptographic schemes, [...] due to Shor's algorithm. While there are currently no such cryptographically relevant quantum computers (CRQC) available, their development is progressing rapidly [...] preparing for the quantum threat should be considered an integral aspect of cyber security risk management.

[...] we currently strongly recommend to deploy PQC in hybrid solutions for most use-cases, i.e. combining a deployed cryptographic scheme with PQC in such a way that the combination remains secure even if one of its components is broken.

[...] The transition should also consider cryptoagility, allowing to ensure a more resilient transition to PQC[...]

—Nov. 27,2024; Securing Tomorrow, Today: Transitioning to PQC

Quantencomputer - Bedrohungsbewertung

> [...] preparing for the quantum threat should be considered an integral aspect of cybersecurity risk management. In an attempt to quantify the risk, the 2023 issue of the Quantum Threat Timeline conducted a survey among 37 international leading experts from academia and industry. Out of these, 17 estimated the risk that a CRQC appears within a 10-year timeframe higher than 5%. Moreover, 10 of these respondents even indicated a likelihood of about 50% or more.
>
> [...] To ensure an acceptable level of readiness, we recommend that these should be protected against "store now, decrypt later" attacks as soon as possible, latest by the end of 2030.
>
> —Nov. 27, 2024; Securing Tomorrow, Today: Transitioning to PQC

> [...] the JVG algorithm completely upends existing time projections. The Advanced Quantum Technologies Institute (AQTI) announced March 2, 2026, "The JVG algorithm requires thousand-fold less quantum computer resources, such as qubits and quantum gates. **Research extrapolations suggest** it will *require less than 5,000 qubits to break encryption methods used in RSA and ECC*."[3]
>
> —March 3, 2026; Securityweek: Quantum Decryption of RSA Is Much Closer Than Expected bzw. Feb. 13 2026; Jesse Van Griensven Thé, Victor Oliveira Santos, Bahram Gharabaghi; A Novel Hybrid Quantum Circuit for Integer Factorization: End-to-End Evaluation in Simulation and Real Quantum Hardware

> **Is RSA Safe? New Study Argues Quantum Computers Face A Hard Ceiling**
>
> A PNAS study proposes Rational Quantum Mechanics, [...] The research estimates a practical upper bound of roughly 200 to 1,000 fully usable qubits, beyond which quantum computers would lose their expected exponential advantage. [... and hence, RSA would remain safe.]
>
> —Matt Swayne; March 19, 2026 - Quantum Insider

▲ Achtung!

Die zugrunde liegende Forschungsarbeit wurde zwar einem Peer-Review unterzogen, aber einige relevante Fragen sind noch nicht beantwortet. **Es ist keine sinnvolle Sicherheitsstrategie darauf zu setzten, dass RSA vielleicht doch sicher bleibt!**

---

[3] Markup wurde nachträglich hinzugefügt. Die zugrundeliegende Forschung hat (Stand März 2026) bisher kein Peer-Review-Verfahren durchlaufen.

Ergänzende Quellen

Podcasts

- Passwort - Der Podcast von heise security
- Nachgehackt - Der IT-Security Podcast
- Spiegel Vulkan Files

  (Es gibt sowohl einen Podcast als auch Artikel (frei/zu bezahlen))

Die NIS 2 Richtlinie

Directive (EU) 2022/2555 of the European Parliament and of the Council of 14 December 2022 on measures for a high common level of cybersecurity across the Union, amending Regulation (EU) No 910/2014 and Directive (EU) 2018/1972, and repealing Directive (EU) 2016/1148 (NIS 2 Directive)

NIS 2 Richtlinie (🇺🇸 *NIS 2 Directive*)

- Die NIS2-Richtlinie ist die zweite EU-Richtlinie zur Netz- und Informationssicherheit (NIS) in der EU.
- *seit 17. Oktober 2024 hätten alle nationalstaaten entsprechende Regelungen in nationales Recht umgesetzt haben sollen und ab 18. Oktober 2024 anwenden sollen*; Deutschland hat dies im Nov. 2025 getan.
- Das Hauptziel ist die Verbesserung der Widerstandsfähigkeit gegen Cyberkriminalität und die Verbesserung des europäischen und nationalen Cybersecurity-Managements.

  Die neue NIS-2-Richtlinie zielt darauf ab, die Widerstandsfähigkeit und Reaktionsfähigkeit des öffentlichen und privaten Sektors zu verbessern. Der Schwerpunkt der Richtlinie liegt auf der Bekämpfung der Cyberkriminalität.
- Die NIS-2-Richtlinie gilt für Organisationen, inkl. Unternehmen und Zulieferer, die durch Erbringung wesentlicher oder wichtiger Dienstleistungen eine entscheidende Rolle für die Aufrechterhaltung der europäischen Wirtschaft und Gesellschaft spielen.
- Die Führungskräfte von betroffenen Einrichtungen sind für die Überwachung der Umsetzung der NIS-2-Richtlinie verantwortlich und können für Verstöße gegen die NIS-2-Richtlinie haftbar gemacht werden (Artikel 20).

Artikel 20, Governance

1. Die Mitgliedstaaten stellen sicher, dass die Leitungsorgane wesentlicher und wichtiger Einrichtungen die von diesen Einrichtungen zur Einhaltung von Artikel 21 ergriffenen Risikomanagementmaßnahmen im Bereich der Cybersicherheit billigen, ihre Umsetzung überwachen und für Verstöße gegen diesen Artikel durch die betreffenden Einrichtungen verantwortlich gemacht werden können. [...]
2. Die Mitgliedstaaten stellen sicher, dass die Mitglieder der Leitungsorgane wesentlicher und wichtiger Einrichtungen an Schulungen teilnehmen müssen, und fordern wesentliche und wichtige Einrichtungen auf, allen Mitarbeitern regelmäßig entsprechende Schulungen anzubieten, um ausreichende Kenntnisse und Fähigkeiten zur Erkennung und Bewertung von Risiken sowie Managementpraktiken im Bereich der Cybersicherheit und deren Auswirkungen auf die von der Einrichtung erbrachten Dienste zu erwerben.

—NIS 2 - KAPITEL IV RISIKOMANAGEMENTMAßNAHMEN UND BERICHTSPFLICHTEN IM BEREICH DER CYBERSICHERHEIT

NIS 2 - Berichtspflichten

- Wesentliche und wichtige Einrichtungen müssen unverzüglich (*in jeden Fall aber innerhalb von 24 Stunden*) über jeden Sicherheitsvorfall unterrichten, der erhebliche Auswirkungen auf die Erbringung ihrer Dienste hat
- Ein Sicherheitsvorfall gilt als erheblich, wenn:

  a. er schwerwiegende Betriebsstörungen der Dienste oder finanzielle Verluste für die betreffende Einrichtung verursacht hat oder verursachen kann;

  b. er andere natürliche oder juristische Personen durch erhebliche materielle oder immaterielle Schäden beeinträchtigt hat oder beeinträchtigen kann.

Von NIS2 betroffene öff. und priv. Einrichtungen[4]

Folgende Organisation mit mehr als 50 Mitarbeitern und einem Umsatz von mehr als 10 Millionen Euro müssen die NIS-2-Richtlinie einhalten (obligatorisch).

- Post- und Kurierdienste
- Abfallwirtschaft
- Chemie
- Lebensmittel
- Herstellung medizinischer Geräten
- Computer und Elektronik
- Maschinen
- Kraftfahrzeuge
- Energie
- Verkehrswesen
- Bankwesen
- Finanzmarkt-Infrastrukturen
- Gesundheitswesen
- Trinkwasserversorgung und -verteilung
- Digitale Infrastrukturen
- Online-Marktplätze
- Online-Suchmaschinen
- Cloud Computing-Dienste

Bis zum 17. April 2025 erstellen die Mitgliedstaaten eine Liste von wesentlichen und wichtigen Einrichtungen und von Einrichtungen, die Domänennamen-Registrierungsdienste erbringen und aktualisieren sie gegebenenfalls regelmäßig — spätestens alle 2 Jahre.

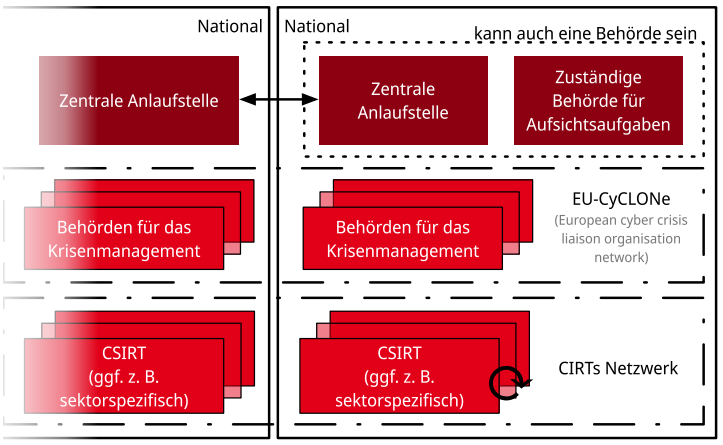
---

[4] Details siehe Anhang I und II der NIS 2 Richtlinie

▲ Achtung!

Jeder Mitgliedstaat erlässt eine *nationale Cybersicherheitsstrategie*, die die strategischen Ziele, die zur Erreichung dieser Ziele erforderlichen Ressourcen sowie angemessene politische und regulatorische Maßnahmen zur Erreichung und Aufrechterhaltung eines hohen Cybersicherheitsniveaus enthält.

NIS 2 - zentrale Einrichtungen



Ein zentraler Gedanke ist die Vernetzung der zuständigen Behörden sowohl auf nationaler als auch auf europäischer Ebene sicherzustellen.

Ⓛ Legende

CSIRT:

Computer Security Incident Response Team

Behörden für das Krisenmanagement:

Sollte es mehr als eine geben, so wird eine explizit benannt, die für die Koordination und das Management von *Cybersicherheitsvorfällen großen Ausmaßes und Krisen* zuständig ist

6. Von der Bedeutung von Schwachstellen

CVSS, CVE, CWE, CVD, KEV, EPSS, VEP

Common Vulnerability Scoring System (CVSS)

Definition von Schwachstellen nach CVE

> "Eine Schwachstelle in der Berechnungslogik (z. B. Code), die in Software- und Hardwarekomponenten gefunden wird und die, wenn sie ausgenutzt wird, zu einer negativen Auswirkung auf die Vertraulichkeit, Integrität oder Verfügbarkeit führt. Die Behebung der Schwachstellen in diesem Zusammenhang umfasst in der Regel Änderungen am Code, kann aber auch Änderungen an der Spezifikation oder sogar die Ablehnung der Spezifikation (z. B. die vollständige Entfernung der betroffenen Protokolle oder Funktionen) beinhalten."
>
> —https://nvd.nist.gov/vuln (Übersetzt mit DeepL)

Unterscheidung von Schwachstellen:

Definition: 0-Day

Eine Schwachstelle, die zum Zeitpunkt ihrer Entdeckung noch nicht (öffentlich) bekannt ist und für die es noch keinen (öffentlich verfügbaren) Patch gibt.

Definition: n-Day

Eine Schwachstelle, die bereits öffentlich bekannt ist und für die es einen Patch gibt, der (kontextabhängig) jedoch noch nicht angewendet wurde.

▲ Achtung!

Auch N-Days sind häufig für Angreifer von Interesse, da es oft eine gewisse Zeit dauert, bis alle Systeme gepatcht sind bzw. überhaupt gepatcht werden (können).

> **Zero-Day Exploits Surge, Nearly 30% of Flaws Attacked Before Disclosure**
>
> [...] shows zero-day and one-day exploitation is accelerating, up from 23.6% in 2024. [...]
>
> —Infosecurity Magazine

Daten von Vulncheck zeigen, dass es in 2025 884 Schwachstellen gab, die ausgenutzt wurden:

- 254 waren *0-Day* Schwachstellen (28.7%)
- 80 waren *1-31-Days* Schwachstellen (9.0%)
- 228 waren *32-365-Days* Schwachstellen (25.8%)
- 92 waren *1-2-Year* Schwachstellen (10.4%)
- 117 waren *2-4-Years* Schwachstellen (13.2%)
- 111 waren *4+ Years* Schwachstellen (12.5%)

Das Common Vulnerability Scoring System (CVSS)[5]

CVSS 4.0 stellt einen Rahmen bereit für die Beschreibung und Bewertung des Schweregrads von Software-/Hardware-/Firmwareschwachstellen.

Die Bewertung der Basiskennzahlen ergibt eine Punktzahl zwischen 0,0 und 10,0. Wobei 0 bedeutet, dass die Schwachstelle (bisher) harmlos ist und 10,0 bedeutet, dass die Schwachstelle sehr gravierend ist.

Harmlos ist im Prinzip damit gleichzusetzen, dass die Schwachstelle nicht ausgenutzt werden kann oder dass die Auswirkungen nicht weiter relevant sind.

---

[5] CVSS 4.0

Gegensätzliche Kräfte bei der Bewertung

Hersteller versuchen tendenziell eine Bewertung zu erhalten, die möglichst niedrig ist.



Sicherheitsforscher versuchen eine möglichst hohe Bewertung zu erhalten.

CVSS umfasst vier Gruppen von Metriken

01 Basis-Metriken (🇺🇸 *Base Metrics*) erfassen die inhärenten Eigenschaften einer Schwachstelle, die sich nicht ändern, wenn sich die Umgebung ändert.

02 Bedrohungs-Metriken (🇺🇸 *Threat Metric Group*) spiegelt die Merkmale einer Schwachstelle wider, die sich im Laufe der Zeit verändern.

03 Umgebungs-Metriken (🇺🇸 *Environmental Metric Group*) erfassen die Eigenschaften einer Schwachstelle, die sich ändern, wenn sich die Umgebung ändert.

04 Ergänzende-Metriken (🇺🇸 *Supplemental*) liefern zusätzliche Informationen, die für die Bewertung einer Schwachstelle nützlich sein können, aber den Schweregrad nicht direkt beeinflussen.

CVSS - Basis-Metriken (*Base Metric Group*)

Bewertung der Ausnutzbarkeit (*Exploitability Metrics*)

- Angriffsvektor (*Attack Vector*)
- Angriffskomplexität (*Attack Complexity*)
- Angriffsanforderungen (*Attack Requirements*)
- Benötigte Privilegien (*Privileges Required*)
- Erforderliche Benutzerinteraktion (*User Interaction*)

Bewertung der Auswirkungen (*Impact Metrics*)

bzgl. des betroffenen Systems (*Vulnerable System*)

- Vertraulichkeit (*Confidentiality Impact*)
- Integrität (*Integrity Impact*)
- Verfügbarkeit (*Availability Impact*)

bzgl. nachgelagerter Systeme (*Subsequent System*)

- Vertraulichkeit (*Confidentiality Impact*)
- Integrität (*Integrity Impact*)
- Verfügbarkeit (*Availability Impact*)

CVSS - Bedrohungs-Metriken (🇺🇸 *Threat Metric Group*)[6]

- Reifegrad des Exploits (🇺🇸 *Exploit Maturity*)

Gibt es bisher nur die Beschreibung der Schwachstelle oder gibt es bereits einen Proof-of-Concept (PoC) Exploit?

---

[6] Die Namen und der Gruppenzuschnitt (hier: 🇺🇸 *Temporal Metric Group*) waren unter CVSS 3.0 anders.

CVSS - Bewertung der Ausnutzbarkeit (🇺🇸 *Exploitability Metrics*)

Attack Vector (AV): Network, Adjacent, Local, Physical

Attack Complexity (AC):
Low, High

Attack Requirements (AT):
None, Present

Privileges Required (PR):
None, Low, High

User Interaction (UI):
None, Passive, Active

Attack Vector

Network

Schwachstellen, die häufig „aus der Ferne ausnutzbar“ sind und als ein Angriff betrachtet werden können, der auf Protokollebene über einen oder mehrere Netzknoten hinweg (z. B. über einen oder mehrere Router) ausgenutzt werden kann.

Adjacent

Der Angriff ist auf eine logisch benachbarte Topologie beschränkt. Dies kann z. B. bedeuten, dass ein Angriff aus demselben gemeinsamen Nahbereich (z. B. Bluetooth, NFC oder IEEE 802.11) oder logischen Netz (z. B. lokales IP-Subnetz) gestartet werden muss.

Local

Der Angreifer nutzt die Schwachstelle aus, indem er lokal auf das Zielsystem zugreift (z. B. Tastatur, Konsole) oder über eine Terminalemulation (z. B. SSH); oder der Angreifer verlässt sich auf die Interaktion des Benutzers, um die zum Ausnutzen der Schwachstelle erforderlichen Aktionen durchzuführen (z. B. mithilfe von Social-Engineering-Techniken, um einen legitimen Benutzer zum Öffnen eines bösartigen Dokuments zu verleiten).

Physical

Der Angreifer muss physisch Zugriff auf das Zielsystem haben, um die Schwachstelle auszunutzen.

Attack Complexity

Wie aufwendig ist es explizite Schutzmaßnahmen ((K)ASLR, Stack Canaries, ...) zu umgehen. Wie wahrscheinlich ist es, dass ein Angriff erfolgreich ist. Im Falle von 🇺🇸 *Race Conditions* können ggf. sehr viele Ausführungen notwendig sein bevor die Race Condition erfüllt ist.

Attack Requirements

Welcher Vorbedingungen (unabhängig von den expliziten Sicherungsmaßnahmen) müssen erfüllt sein, damit die Schwachstelle ausgenutzt werden kann. (z. B. der Nutzer muss sich an seinem Smartphone mindestens einmal seit dem Boot angemeldet haben (*After-First-Use* vs. *Before-First-Use*.))

Privileges Required

Welche Privilegien muss der Angreifer mindestens haben, um die Schwachstelle auszunutzen (Sind Administratorrechte erforderlich oder reichen normale Benutzerrechte).

User Interaction

Passiv bedeutet hier, dass der Nutzer unfreiwillig die Schwachstelle ausnutzt ohne bewusst Schutzmechanismen zu unterlaufen. Aktiv bedeutet, dass der Nutzer aktiv Interaktionen unternimmt, um die Schutzmechanismen des Systems auszuhebeln (z. B. durch das Installieren einer nicht-signierten Anwendung aus dem Internet).

CVSS - Bewertung der Auswirkung auf das betroffene System/Vulnerable System Impact Metrics

Confidentiality Impact (C):

None, Low, High

Integrity Impact (I):

None, Low, High

Availability Impact (A):

None, Low, High

CVSS - Bewertung der Auswirkung auf das nachgelagerte System/Vulnerable System Impact Metrics

Confidentiality Impact (C):

None, Low, High

Integrity Impact (I):

None, Low, High

Availability Impact (A):

None, Low, High

✎ Diskussion: Schwachstellen und Ihre Bewertung

Ihnen liegt eine externe Festplatte mit AES-256-XTX basierter Hardwareverschlüsselung vor. Das Entsperren der Festplatte geschieht mit Hilfe eines speziellen Programms, dass ggf. vorher installiert werden muss und als Schutzmechanismus ein Passwort vorsieht.

Das Clientprogramm hasht erst das Passwort clientseitig, bevor es den Hash an den Controller der Festplatte überträgt. Die Firmware des Controllers validiert das Passwort in dem es den gesendeten Hash direkt mit dem bei der Einrichtung übermittelten Hash vergleicht; d. h. es finden keine weiteren sicherheitsrelevanten Operationen außer dem direkten Vergleich statt. Zum Entsperren der Festplatte ist es demzufolge ausreichend, den Hash aus der Hardware auszulesen und diesen an den Controller zu senden, um die Festplatte zu entsperren. Danach kann auf die Daten frei zugegriffen werden.

1. Ermitteln Sie den CVSS 4.0 Score für diese Schwachstelle. (CVSS Rechner)
2. Welche Anwendungsfälle sind für diese Schwachstelle denkbar?

Zuverlässigkeit von CVSS Bewertungen

Internet-wide Vulnerability Enables Giant DDoS Attacks

[...] MadeYouReset is officially tracked as CVE-2025-8671, with the same "high" 7.5 CVSS rating that Rapid Reset received.

The issue is also being tracked under a variety of other CVEs where it pertains to different HTTP/2 implementations. For example, MadeYouReset is a high-grade 8.2-rated issue (CVE-2025-55163) in the Netty application framework but only a medium-severity 6.9-rated issue (CVE-2025-54500) to F5 Networks' BIG-IP application delivery controllers (ADCs). [...]

—August, 18th, 2025 - Dark Reading

Common Vulnerabilities and Exposures (CVE)

Zweck von CVEs

- Schwachstellen eindeutig identifizieren und bestimmten Versionen eines Codes (z. B. Software und gemeinsam genutzte Bibliotheken) mit diesen Schwachstellen verknüpfen.
- Kommunikationsgrundlage bilden, damit mehrere Parteien über eine eindeutig identifizierte Sicherheitslücke diskutieren können. National Vulnerabilities Database - NIST

6. Juni 2026 - NVD Dashboard

Time Period	New CVEs Received	New CVEs Enriched
Today	26	0
This Week	1576	1068
This Month	1576	1068
Last Month	6984	3619
This Year	30688	20499

National Vulnerability Database (NVD)[7]

- Auflistung aller CVEs und deren Bewertung
- Alle Schwachstellen in der NVD sind mit einer CVE-Kennung versehen
- Die NVD ist ein Produkt der NIST Computer Security Division, Information Technology Laboratory
- Verlinkt häufig weiterführend Seiten, die Lösungshinweise und Tools bereitstellen, um die Schwachstelle zu beheben
- Verweist auf entsprechende Schwachstellen gemäß CWEs
- Verlinkt gelegentlich *PoC* Exploits (🇺🇸 *Proof-of-Concept Exploits*)

---

[7] Die NIS 2 Richtlinie der EU sieht auch den Aufbau einer europäischen Schwachstellen-Datenbank vor. Aktuell ist die NVD die zentrale Anlaufstelle bzgl. Schwachstellen.

Common Weakness Enumeration (CWE)

- eine kollaborativ entwickelte, vollständig durchsuchbare, kategorisierte Liste von Typen von Software- und Hardware-Schwachstellen und deren Beschreibung, dient als:
  - gemeinsame Sprache,
  - Messlatte für Sicherheitstools,
  - als Grundlage für die Identifizierung von Schwachstellen sowie für Maßnahmen zur Abschwächung und Prävention.

CWE - Schwachstellenkatalog TOP 10 in 2023

Rank	ID	Name
1	CWE-787	Out-of-bounds Write
2	CWE-79	Improper Neutralization of Input During Web Page Generation ("*Cross-site Scripting*")
3	CWE-89	Improper Neutralization of Special Elements used in an SQL Command ("*SQL Injection*"")
4	CWE-416	Use After Free
5	CWE-78	Improper Neutralization of Special Elements used in an OS Command ("*OS Command Injection*")
6	CWE-20	Improper Input Validation
7	CWE-125	Out-of-bounds Read
8	CWE-22	Improper Limitation of a Pathname to a Restricted Directory ("*Path Traversal*")
9	CWE-352	Cross-Site Request Forgery (CSRF)
10	CWE-434	Unrestricted Upload of File with Dangerous Type

Request Forgery = *Anfragefälschung*

Fest codierte Cloud-Zugangsdaten in populären Apps entdeckt

Betroffen sind mehrere Apps mit teils Millionen von Downloads. Den Entdeckern zufolge gefährdet dies nicht nur Backend-Dienste, sondern auch Nutzerdaten.

Sicherheitsforscher von Symantec haben Anwendungen aus dem Google Play Store und dem Apple App Store untersucht und dabei festgestellt, dass mehrere Apps mit teils Millionen von Downloads fest codierte und unverschlüsselte Anmeldedaten für verschiedene Clouddienste enthalten. Entdeckt wurden sowohl Schlüssel für den Zugang zu AWS-Ressourcen als auch solche für Microsoft Azure. [...]

—23.10.2024 Golem.de

CVE-2023-51034 - *Arbitrary Code Execution*

> TOTOlink EX1200L V9.3.5u.6146_B20201023 is vulnerable to arbitrary command execution via the cstecgi.cgi UploadFirmwareFile interface.
>
> —Published: December 22, 2023; Last modified: January 2, 2024

Bewertung: CVSS V3.1: 9.8 Critical

PoC Exploit: 815yang.github.io

Weakness Enumeration:

CWE-434 Unrestricted Upload of File with Dangerous Type

Bei TOTOlink EX1200L handelt es sich um einen Wifi Range Expander.

PoC ≙ Proof-of-Concept

CWE-434 Unrestricted Upload of File with Dangerous Type

Beschreibung	Art der Einführung	Scope
Das Produkt ermöglicht es dem Angreifer, Dateien gefährlicher Typen hochzuladen oder zu übertragen, die in der Produktumgebung automatisch verarbeitet werden können.	Diese Schwäche wird durch das Fehlen einer Sicherheitstaktik während der Architektur- und Entwurfsphase verursacht.	Willkürliche Codeausführung ist möglich, wenn eine hochgeladene Datei vom Empfänger als Code interpretiert und ausgeführt wird. [...] Somit ist ggf. die Integrität, Vertraulichkeit und Verfügbarkeit betroffen.

—Mitre.org (2023; übersetzt mit DeepL)

CVE-2023-51034 - PoC (gekürzt)

Initiale Anfrage

```
POST /cgi-bin/cstecgi.cgi HTTP/1.1
[...]
{
    "FileName":
        ";ls../>/www/yf.txt;",
    "topicurl":
        "UploadFirmwareFile"
}
```

Abfrage der Datei (hier: `yf.txt`)

```
GET /yf.txt HTTP/1.1
[...]
Connection: close
```

Das Ergebnis ist eine Datei mit der Auflistung der Dateien im Verzeichnis (`..`).

CVE-2023-51034 - zugrundeliegende Schwachstelle

```
Var = (const char *)websGetVar(a1, "FileName", &byte_42FE28);
v3 = (const char *)websGetVar(a1, "FullName", &byte_42FE28);
v4 = (const char *)websGetVar(a1, "ContentLength", &word_42DD4C);
v5 = websGetVar(a1, "flags", &word_42DD4C);
v6 = atoi(v5);
Object = cJSON_CreateObject();
v8 = fopen("/dev/console", "a");
v9 = v8;
if ( v8 ) {
    fprintf(v8, "[%s:%d] FileName=%s,FullName=%s,ContentLength=%s\n",
                "UploadFirmwareFile", 751, Var, v3, v4);
    fclose(v9);
}
v10 = strtol(v4, 0, 10) + 1;
strcpy(v52, "/tmp/myImage.img");
doSystem("mv %s %s", Var, v52);
```

Die Lücke ist auf die folgenden Zeilen zurückzuführen:

```
Var = (const char *)websGetVar(a1, “FileName”, &byte_42FE28);
...
doSystem(“mv %s %s”, Var, v52);
```

Der Aufruf von doSystem ermöglicht die Ausführung von beliebigem Code. Der Angreifer kann den Wert von Var so manipulieren, dass er quasi beliebigen Code ausführen kann.

Ausgenutzte Schwachstellen

Der Known Exploited Vulnerabilities (KEV) Katalog der CISA umfasst Produkte deren Schwachstellen ausgenutzt wurden oder aktiv ausgenutzt werden.

- Kriterien für die Aufnahme in den KEV Katalog:
  1. Eine CVE-Id liegt vor.
  2. Die Schwachstelle wird aktiv ausgenutzt (🇺🇸 *Active Exploitation*) (ggf. reicht es jedoch wenn „nur“ ein *Honeypot* aktiv angegriffen wurde) - ein PoC reicht nicht aus.
  3. Eine Handlungsempfehlung liegt vor (z. B. Patch, Workaround oder vollständige Abschaltung).
- Firmen sollten die KEV *Schwachstellen priorisieren*, um die Wahrscheinlichkeit eines erfolgreichen Angriffs zu verringern.

CISA = *Cybersecurity and Infrastructure Security Agency* (oder *America's Cyber Defense Agency*)

Ausgewählte amerikanische Behörden sind sogar verpflichtet innerhalb vorgegebener Zeiträume zu reagieren.

Erzwungene Außerbetriebnahme von Produkten

Abschaltbefehl: US-Behörden müssen Ivanti-Geräte vom Netz nehmen

[...] In einer jetzt veröffentlichten "Emergency Directive" weist die US-amerikanische Cybersicherheitsbehörde CISA alle Bundesbehörden an, Produkte vom Typ "Ivanti Connect Secure" oder "Ivanti Policy Secure" unverzüglich vom Netz zu nehmen. Sie reagiert damit auf massenhafte Angriffe gegen die schadhaften Geräte. [...]

—02.02.2024 - Heise.de

Alte CVEs können relevant und im KEV Katalog sein ...

CISA flags actively exploited Office relic [...]

CISA has added a [...] security holes to its actively exploited list [...] a years-old flaw in Microsoft Office.

The latest update to CISA's Known Exploited Vulnerabilities catalog flags [...] *CVE-2009-0556*, a PowerPoint code injection bug that's been lurking for more than 15 years.

[...] CISA also flagged CVE-2009-0556, a Microsoft Office PowerPoint code injection vulnerability rated 8.8 on the CVSS scale. The bug, confirmed by Microsoft back in 2009, allows remote attackers to execute arbitrary code via memory corruption when a user opens a specially crafted PowerPoint file. Microsoft patched the issue years ago as part of MS09-017, but its appearance in the KEV catalog indicates that unpatched or unsupported systems are still being successfully targeted.

—Jan. 2026 - The Register

2024 CWE Top 10 KEV Weaknesses

CWE ID	Schwachstelle	Avg. CVSS
CWE-787	Out-of-bounds Write	75.59
CWE-843	Access of Resource Using Incompatible Type (*Type Confusion*)	24.91
CWE-78	Improper Neutralization of Special Elements used in an OS Command (*OS Command Injection*)	24.27
CWE-94	Improper Control of Generation of Code (*Code Injection*)	23.64
CWE-502	Deserialization of Untrusted Data	23.07
CWE-22	Improper Limitation of a Pathname to a Restricted Directory (*Path Traversal*)	19.52
CWE-306	Missing Authentication for Critical Function	17.60
CWE-89	Improper Neutralization of Special Elements used in an SQL Command (*SQL Injection*)	15.62
CWE-416	Use After Free	15.43
CWE-77	Improper Neutralization of Special Elements used in a Command (*Command Injection*)	14.90

Schwachstellen, die auf Fehler beim Speicherzugriff zurückzuführen sind, sind nicht (mehr) notwendig!

Google hails move to Rust for huge drop in memory vulnerabilities

[...] Memory access vulnerabilities often occur in programming languages that are not memory safe. In 2019, memory safety issues accounted for 76% of all Android vulnerabilities.

[...] the transition to memory safe languages through the gradual use of memory safe code in new projects and developments over a five year period. The results showed that despite a gradual rise in code [still] being written in memory unsafe languages, memory safety vulnerabilities dropped significantly.

[...] there has been a significant drop in the number of memory-related vulnerabilities, with memory safe vulnerabilities down to 24% in 2024 [...]

—26. September 2024 - Techradar.com

Offenlegung von Sicherheitslücken nach CISA [8]

Coordinated Vulnerability Disclosure (CVD)

1. Sammlung von Schwachstellenmeldungen
2. Analyse der Schwachstellenmeldungen zusammen mit den Herstellern, um die Sicherheitsauswirkungen zu verstehen.
3. Entwicklung von Strategien zur Eindämmung der Schwachstellen; insbesondere Entwicklung von notwendigen Patches.
4. Anwendung der Strategien zur Eindämmung der Schwachstellen in Zusammenarbeit mit dem Hersteller und ggf. betroffenen Nutzern.
5. Veröffentlichung der Schwachstellenmeldung in Abstimmung mit der Quelle des Schwachstellenberichts und dem Hersteller.

CISA (America's Cybersecurity and Infrastructure Security Agency/Cyber Defense Agency).

Quellen für Schwachstellen

- Eigene Schwachstellenanalysen
- Überwachung öffentlicher Quellen
- Direkte Meldungen von Herstellern, Forschern und Nutzern

---

[8] Das BSI verfährt ähnlich; tut sich aber sehr schwer.

Zeitlicher Rahmen für die Offenlegung von Sicherheitslücken

Der Zeitrahmen für die Offenlegung von Sicherheitslücken wird durch folgende Faktoren bestimmt:

- Aktive Ausnutzung der Schwachstelle
- besonders kritische Schwachstellen
- Auswirkungen auf Standards
- bereits öffentlich bekannt (zum Beispiel durch einen „naïven“` Forscher)
- Auswirkungen auf die kritische Infrastruktur, öffentliche Gesundheit und Sicherheit
- die Verfügbarkeit von effektiven Eindämmungsmaßnahmen
- das Verhalten des Herstellers und die Möglichkeit der Entwicklung eines Patches
- Schätzung des Herstellers wie lange es dauert einen Patch zu entwickeln, zu testen und auszurollen.

Welche neuen Schwachstellen werden in absehbarer Zeit ausgenutzt?

◉ Beobachtung

Am 1. Oktober 2023 hat die NVD 139.473 CVEs veröffentlicht. In den folgenden 30 Tagen wurden 3.852 CVEs beobachtet, die ausgenutzt (🇺🇸 *exploited*) wurden.

Ca. 5-6% aller Schwachstellen werden „irgendwann“ ausgenutzt. [9]

? Frage

Wie stelle ich sicher, dass ich meine Bemühungen zum Beseitigen der Schwachstellen auf diejenigen konzentriere, die am wahrscheinlichsten zeitnahe ausgenutzt werden?

---

[9] Fortinet, Threat Landscape Report Q2 2018

Nutzung des CVSS als Grundlage für die Schätzung?

Annahme: Schwachstellen mit einem CVSS Score ≥ 7 (d. h. mit einer Bewertung von Hoch oder kritisch) werden ausgenutzt.

- 80.024 Schwachstellen haben einen CVSS Score ≥ 7

  Ausgenutzt wurden: 3.166

- 59.449 Schwachstellen haben eine CVSS < 7

  Ausgenutzt wurden: 686

Zusammenfassung

Die Strategie „Priorisierung von Schwachstellen mit einem bestimmten CVSS Score“ (hier ≥ 7) ist keine geeignete Strategie, da sie nicht alle relevanten Schwachstellen erfasst (686 *False Negatives*) und - ganz insbesondere - zu viele Schwachstellen (76.858 *False Positives*) erfasst, die nicht ausgenutzt werden.

Exploit Prediction Scoring System (EPSS)

- EPSS ist eine Methode zur *Bewertung der Wahrscheinlichkeit*, dass eine Schwachstelle in den nächsten 30 Tagen ausgenutzt wird.
- EPSS basiert auf der Analyse von Schwachstellen, die in den letzten 12 Monaten ausgenutzt wurden.
- EPSS nutzt KI basierend auf folgenden Informationen (Stand Jan. 2024):
  - Hersteller
  - Alter der Schwachstelle (Tage seit der Veröffentlichung des CVEs)
  - die Beschreibung der Schwachstelle
  - betroffene CWEs
  - CVSS Bewertungen der Schwachstellen
  - Wird der CVE auf bekannten Listen diskutiert bzw. aufgelistet?
  - Gibt es öffentliche verfügbare Exploits?

Nutzung des EPSS für die Schätzung? [10]

Annahme: Schwachstellen mit EPSS 10% und größer werden ausgenutzt werden.

- 3.735 Schwachstellen haben eine Wahrscheinlichkeit von EPSS 10% und größer

  Ausgenutzt wurden: 2.435

- 135.738 Schwachstellen haben ein EPSS < 10%

  Ausgenutzt wurden: 1.417

Zusammenfassung

Die Strategie „Priorisierung von Schwachstellen mit einem EPSS von 10% und höher“ ist eine geeignete*re* Strategie, da sehr viele relevante Schwachstellen erfasst werden und - ganz insbesondere - die Anzahl der zu beachtenden Schwachstellen ganz massiv reduziert wird ohne die Gesamtqualität *zu stark* zu beeinflussen.

---

[10] Enhancing Vulnerability Prioritization: Data-Driven Exploit Predictions with Community-Driven Insights

Schwachstellenmanagement

Vulnerabilities Equities Process (VEP) (USA) [11]

> [...] Der *Vulnerability-Equity-Process (VEP)* wägt ab, ob Informationen über Schwachstellen an den Hersteller/Lieferanten weitergegeben werden sollen, in der Erwartung, dass sie gepatcht werden, oder ob die Kenntnis der Schwachstelle vorübergehend auf die US-Regierung und möglicherweise andere Partner beschränkt werden soll, damit sie für Zwecke der nationalen Sicherheit und der Strafverfolgung, wie z. B. nachrichtendienstliche Erfassung, militärische Operationen und/oder Spionageabwehr, genutzt werden können. [...]
>
> —Übersetzung: DeepL

Insbesondere durch die föderale Struktur in Deutschland kann es ggf. dazu kommen, dass bezüglich der Handhabung von Schwachstellen unterschiedliche rechtliche Regelungen gelten werden - je nachdem ob die Behörde eine Bundes- oder Landesbehörde ist.

---

[11] Die rechtlichen Rahmenbedingungen bzgl. eines effektiven Schwachstellenmanagements sind in Deutschland gerade in der Diskussion. (Stand Jul. 2024); Schwachstellen, die direkt an das BSI gemeldet werden, unterliegen dem vorher diskutierten CVD.

Vulnerabilities Equities Process (VEP) (USA)

> [...] Die Entscheidung der US-Regierung, ob eine Schwachstelle veröffentlicht oder eingeschränkt werden soll, ist nur ein Element des Prozesses zur Bewertung der Schwachstellen und ist nicht immer eine binäre Entscheidung. Andere Optionen, die in Betracht gezogen werden können, sind die Verbreitung von Informationen zur Schadensbegrenzung an bestimmte Stellen, ohne die jeweilige Schwachstelle offenzulegen, die Einschränkung der Nutzung der Schwachstelle durch die US-Regierung in irgendeiner Weise, die Information von Regierungsstellen der USA und verbündeter Staaten über die Schwachstelle [...].
>
> —Übersetzung: DeepL

Vulnerabilities Equities Process (VEP) (USA)

> [...] Alle diese Entscheidungen müssen auf der Grundlage des Verständnisses der Risiken einer Verbreitung, des potenziellen Nutzens von Schwachstellen durch die Regierung sowie der Risiken und Vorteile aller dazwischen liegenden Optionen getroffen werden. [...]
>
> —Übersetzung: DeepL

7. Verschlüsselung

Zentrale Begriffe

Definition: Klartext (🇺🇸 *Plaintext*)

Die Originalnachricht, die verschlüsselt werden soll.

Definition: Geheimtext oder Chiffretext (🇺🇸 *Ciphertext*)

Die kodierte/verschlüsselte Nachricht.

(Im Deutschen gelegentlich auch Kryptogramm genannt.)

Definition: Verschlüsselung (🇺🇸 *Encryption*)

Der Prozess der Umwandlung von Klartext in Geheimtext.

Definition: Entschlüsselung (🇺🇸 *Decryption*)

Der Prozess der Wiederherstellung des Klartextes aus dem Geheimtext.

Definition: Kryptographie (🇺🇸 *Cryptography*)

Das Studiengebiet der Verschlüsselungsschemata.

Definition: Kryptoanalyse (🇺🇸 *Cryptanalysis*)

Methoden und Techniken, die zur Gewinnung von Informationen aus einer verschlüsselten Nachricht dienen.

Analyse von kryptographischen Verfahren.

Definition: Kryptologie (🇺🇸 *Cryptology*)

Die Bereiche Kryptographie und Kryptoanalyse.

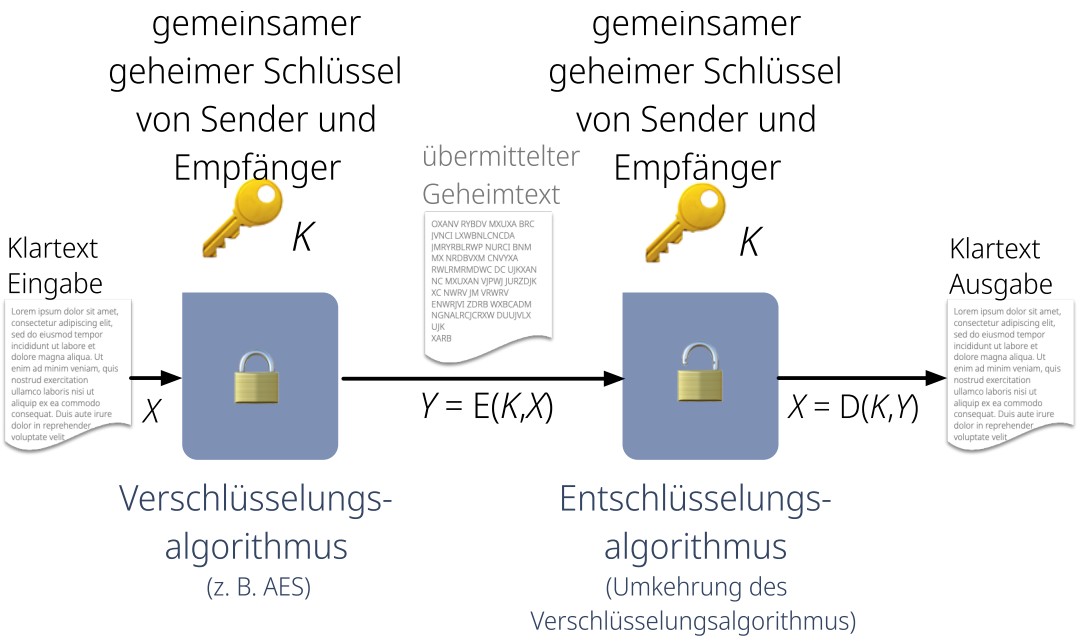
Kryptografische Systeme können entlang dreier unabhängiger Dimensionen charakterisiert werden

> ◎ Bemerkung
>
> Eine Permutation ist eine Folge von Vertauschungen.

1. Die Art der Operation, die zur Umwandlung von Klartext in Chiffretext verwendet wird:
   - Substitution
   - Transposition (Vertauschungen)
2. Die Anzahl der verwendeten Schlüssel.

   Symmetrisch: Ein-Schlüssel bzw. **Secret-Key**- (*konventionelle Verschlüsselung*)
   Asymmetrisch: Zwei-Schlüssel bzw. **Public-Key**-Verschlüsselung
3. Die Art und Weise, in der der Klartext verarbeitet wird:
   - Blockchiffre
   - Stromchiffre

Vereinfachtes Modell der symmetrischen Verschlüsselung



Symmetrisches Verschlüsselungsmodell

Es gibt zwei Voraussetzungen für die sichere Verwendung der herkömmlichen Verschlüsselung:

1. Ein starker Verschlüsselungsalgorithmus.
2. Effektive Schlüsselverwaltung:
    a. Sender und Empfänger müssen Kopien des geheimen Schlüssels auf sichere Weise erhalten haben und
    b. den Schlüssel sicher aufbewahren.

Sicherheit von Verschlüsselungsschemata

Bedingungslos Sicher (🇺🇸 *Unconditionally Secure*)

- Unabhängig davon wie viel Zeit ein Gegner hat, ist es ihm unmöglich, den Geheimtext zu entschlüsseln, weil die erforderlichen Informationen nicht vorhanden sind.

Rechnerisch Sicher (🇺🇸 *Computationally Secure*)

- Die Kosten für das Brechen der Chiffre übersteigen den Wert der verschlüsselten Informationen.
- Die zum Knacken der Chiffre benötigte Zeit übersteigt die Lebensdauer der Informationen.

? Frage

Wie lange könnte der Nutzen einer bestimmten Information andauern?

Angriffe auf Verschlüsselungsschemata

Kryptoanalyse

- Der Angriff beruht auf der Art des Algorithmus und einer gewissen Kenntnis der allgemeinen Merkmale des Klartextes.
- Der Angriff nutzt die Eigenschaften des Algorithmus aus, um zu versuchen, einen bestimmten Klartext zu entschlüsseln oder den verwendeten Schlüssel zu ermitteln.

Brute-force Angriff ( *brachiale Gewalt*)

- Der Angreifer probiert jeden möglichen Schlüssel an einem Stück Chiffretext aus, bis er eine verständliche Übersetzung in Klartext erhält.
- Im Durchschnitt muss die Hälfte aller möglichen Schlüssel ausprobiert werden, um Erfolg zu haben.

Substitutionschiffre

Substitutionsverfahren - Allgemeine Vorgehensweise

- Bei der Substitution werden die Buchstaben des Klartextes durch andere Buchstaben oder durch Zahlen oder Symbole ersetzt.
- Wenn der Klartext als eine Folge von Bits betrachtet wird, beinhaltet die Substitution das Ersetzen von Bitmustern des Klartextes durch Bitmuster des Geheimtextes.

Cäsar-Chiffre

- Einfachste und früheste bekannte Verwendung einer Substitutions-Chiffre; verwendet von Julius Cäsar.
- Dabei wird jeder Buchstabe des Alphabets durch einen Buchstaben ersetzt, der drei Stellen weiter hinten im Alphabet steht.
- Am Ende des Alphabets wird wieder am Anfang begonnen. Somit folgt auf den Buchstabe Z der Buchstabe A.

unverschlüsselt: `meet me after the toga party`

verschlüsselt: `PHHW PH DIWHU WKH WRJD SDUWB`

Monoalphabetische Chiffren

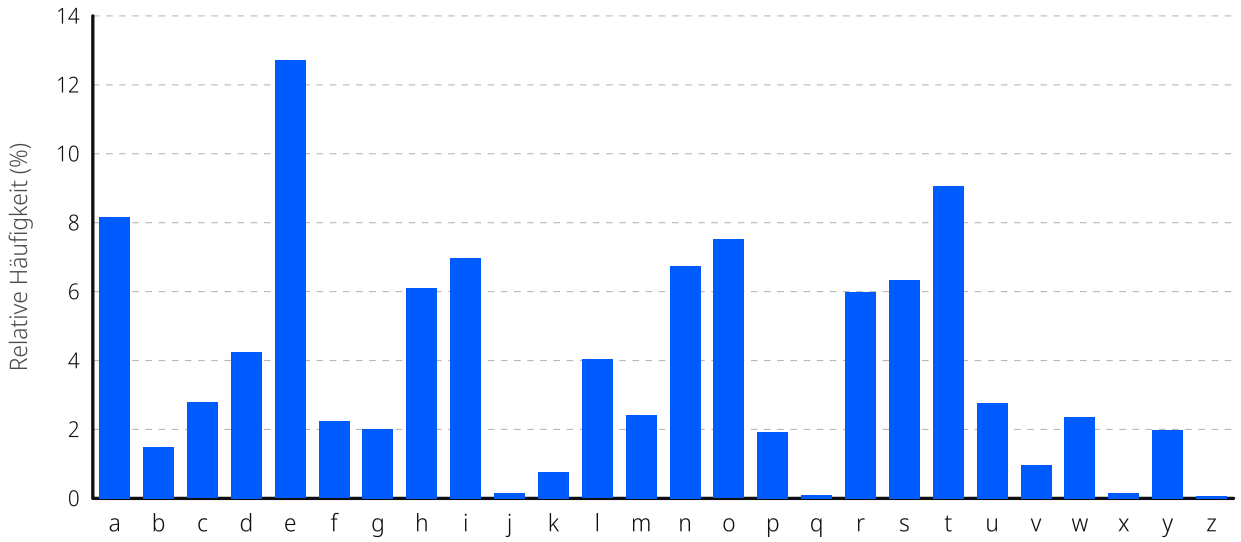
- Eine Permutation einer endlichen Menge von Elementen S ist eine geordnete Folge aller Elemente von S, wobei jedes Element genau einmal vorkommt.

Beispiel

Zeichen	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z
Ersetzung	d	f	v	e	n	k	i	b	s	p	t	q	l	w	u	c	x	r	j	g	z	m	a	h	y	o

- Wenn die „Chiffre“-Zeile (siehe Cäsar-Chiffre) eine beliebige Permutation der 26 alphabetischen Zeichen sein kann, dann gibt es 26! (*26 Fakultät*) oder mehr als $4 \cdot 10^{26}$ mögliche Schlüssel.
  - Dies ist um 10 Größenordnungen größer als der Schlüsselraum des Verschlüsselungsalgorithmus DES!
  - Der Ansatz wird als monoalphabetische Substitutions-Chiffre bezeichnet, da pro Nachricht ein einziges Chiffre-Alphabet verwendet wird.

Angriffsvektor: Häufigkeit der (hier: englischen) Buchstaben[12]



[12]Analyse des Concise Oxford Dictionary (9th edition, 1995) – https://www.nd.edu

Transpositionschiffre

Rail Fence Chiffre

- Einfachste Transpositions-Chiffre (d. h. Chiffre basierend auf `Vertauschung`).
- Der Klartext wird als eine Folge von Diagonalen aufgeschrieben und dann als eine Folge von Zeilen abgelesen.

Beispiel

Um die Nachricht: „Meet me after the Toga-Party“ mit einer Rail Fence Chiffre der Tiefe 2 (Schlüssel) zu verschlüsseln, würden wir schreiben:

```
m e m a t r h t g p r y
 e t e f e t e o a a t
```

Die verschlüsselte Nachricht ist: MEMATRHTGPRYETEFETEOAAT

Public-Key Kryptographie

Schlüsselbegriffe von Public-Key-Kryptosystemen

Klartext **(*Plaintext*):**
: Die lesbare Nachricht oder Daten, die dem Algorithmus als Eingabe dienen.

***Verschlüsselungsalgorithmus*:**
: Führt verschiedene Umwandlungen des Klartextes durch.

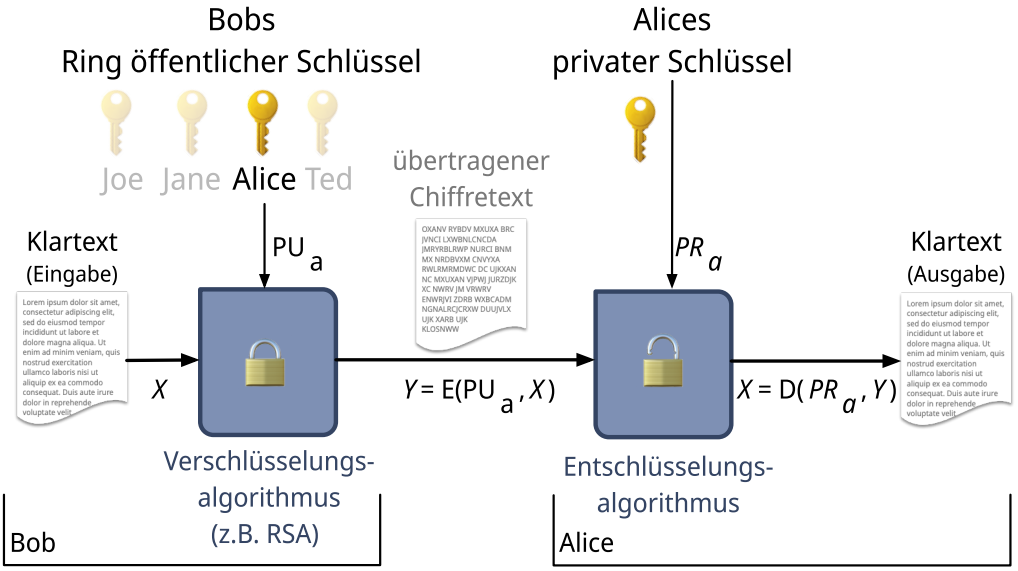
***Öffentlicher Schlüssel*:**
: Wird für *Verschlüsselung* oder *Entschlüsselung* verwendet.

***Privater Schlüssel*:** Verwendet für *Verschlüsselung* oder *Entschlüsselung*.

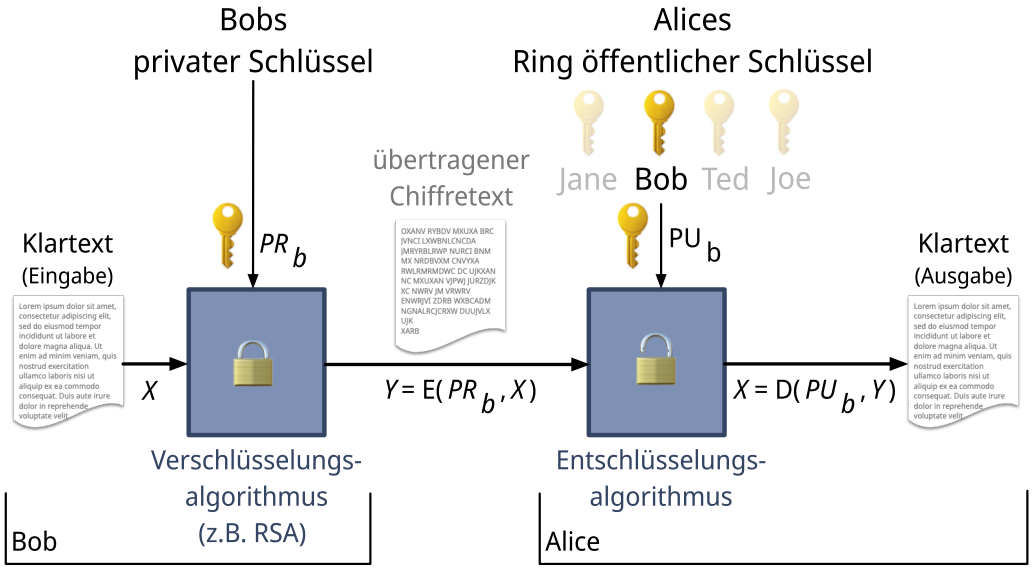
Chiffretext **(*Ciphertext*):**
: Die verschlüsselte Nachricht, die als Ausgabe produziert wird.

***Entschlüsselungsalgorithmus*:**
: Nimmt den Geheimtext und den passenden Schlüssel entgegen und erzeugt den ursprünglichen Klartext.

Verschlüsselung mit öffentlichem Schlüssel



Verschlüsselung mit privatem Schlüssel



Terminologie bzgl. asymmetrischer Verschlüsselung

- Asymmetrische Schlüssel

  Man spricht von asymmetrischen Schlüsseln, wenn man zwei zusammengehörige Schlüssel hat: ein öffentlicher und ein privater Schlüssel. Zusammen werden diese zur Durchführung komplementärer Operationen verwendet werden, z. B. Ver- und Entschlüsselung oder Signaturerstellung und Signaturprüfung.

- Public-Key-Zertifikat

  Ein Public-Key-Zertifikat ist ein digitales Dokument, das mit dem privaten Schlüssel einer Zertifizierungsstelle ( *Certification Authority*) ausgestellt und digital signiert wird und den Namen eines Teilnehmers an einen öffentlichen Schlüssel bindet. Das Zertifikat gibt an, dass der im Zertifikat genannte Teilnehmer die alleinige Kontrolle und den Zugriff auf den entsprechenden privaten Schlüssel hat.

- Public-Key (asymmetrischer) kryptografischer Algorithmus

  Ein Public-Key (asymmetrischer) kryptografischer Algorithmus ist ein Algorithmus, der zwei zusammengehörige Schlüssel verwendet: Einen öffentlichen und einen privaten Schlüssel. Die beiden Schlüssel haben die Eigenschaft, dass die Ableitung des privaten Schlüssels aus dem öffentlichen Schlüssel rechnerisch nicht machbar ist bzw. sein sollte (vgl. Quantenkryptografie).

- Public-Key-Infrastruktur (PKI)

  Public-Key-Infrastruktur umfasst eine Reihe von Richtlinien, Prozessen, Serverplattformen, Software und Workstations, die für die Verwaltung von Zertifikaten und öffentlich-privaten Schlüsselpaaren verwendet werden, einschließlich der Möglichkeit, Public-Key-Zertifikate auszustellen, zu pflegen und zu widerrufen.

✎ Zwischenfrage

7.1. Verschlüsselung mit Public-Private-Key Verfahren

Wenn Alice eine mit Bobs öffentlichen Schlüssel verschlüsselte Nachricht an ihn schickt, welches Sicherheitsproblem kann dann aufkommen?

(Kryptographisches) Hashing

Hashfunktionen

- Eine Hashfunktion H akzeptiert eine beliebig lange Nachricht M als Eingabe und gibt einen Wert fixer Größe zurück: h = H(M).
- Wird oft zur Gewährleistung der Datenintegrität verwendet. Eine Änderung eines beliebigen Bits in M sollte mit hoher Wahrscheinlichkeit zu einer Änderung des Hashwerts h führen.

  (Jedes Bit in $H(M_{\text{ein Bit geändert}})$ sollte mit der Wahrscheinlichkeit ½ gekippt sein.)
- Kryptographische Hashfunktionen werden für Sicherheitsanwendungen benötigt. Mögliche Anwendungen:
  - Authentifizierung von Nachrichten
  - Digitale Signaturen
  - Speicherung von Passwörtern

Beispiel: Berechnung von Hashwerten mittels MD5

```
md5("Hello0") = 5ed715782191ee6041cb4d66f29b1121
md5("hello1") = 5ac78c81d1b3c28c8db48f57dd2b90b3

md5("Dieses Passwort ist wirklich total sicher
    und falls Du es mir nicht glaubst, dann
    tippe es zweimal hintereinander blind
    fehlerfrei ein.")
        = 8fcf22b1f8327e3a005f0cba48dd44c8
```

Warnung

Die Verwendung von MD5 dient hier lediglich der Illustration. In realen Anwendung sollte MD5 nicht mehr verwendet werden, da es nachgewiesene Schwachstellen aufweist.

Verschlüsselung & Hashing ⇒ Signaturen

Signieren von Nachrichten

Alice signiert eine Nachricht X mit ihrem privaten Schlüssel.

Alice: $[E(PR_{Alice}, H=Digest(X)), X]$

Bob prüft die Nachricht X auf Authentizität:

Bob: $D(PU_{Alice}, H) \stackrel{?}{=} Digest(X)$

8. Passwortsicherheit

Verwendung von Passwörtern

Beobachtung

Klassische Passwörter werden (noch immer) in zahlreichen Bereichen verwendet.

Beispiele sind Smartphones, Cryptosticks, Logins für Computer oder verschlüsselte Dateien und Datenträger.

Ist Passwortwiederherstellung nicht „trivial“?

> **59 Prozent aller Passwörter in unter 60 Minuten knackbar**
>
> *Forscher haben per Brute-Force-Methode mit einer Nvidia Geforce RTX 4090 Millionen von Passwörtern aus dem Darknet geknackt.*
>
> [...] Sicherheitsforscher von Kaspersky haben untersucht, wie schnell sich gängige Passwörter mit einer modernen GPU vom Typ Nvidia Geforce RTX 4090 knacken lassen. Durchgeführt wurde die Untersuchung anhand einer Datenbank mit 193 Millionen echten Nutzerpasswörtern, die die Forscher aus dem Darknet bezogen. Sämtliche Passwörter lagen dabei in Form von gesalzenen MD5-Hashes vor. [...]
>
> —21. Juni 2024: golem.de

> **An AI just cracked your password.**
>
> We used [...] PassGAN to run through a list of 15,680,000 passwords. [...]
>
> Time It Takes Using AI to Crack Your Password

# of Chars	Numbers Only	Lowercase Letters	Lower- & Uppercase Letters	Numbers, Upper- & Lowercase Letters	Numbers, Upper- & Lowercase Letters, Symbols
4	Instantly	Instantly	Instantly	Instantly	Instantly
5	Instantly	Instantly	Instantly	Instantly	Instantly
6	Instantly	Instantly	Instantly	Instantly	4 Seconds
7	Instantly	Instantly	22 Seconds	42 Seconds	6 Minutes
8	Instantly	3 Seconds	19 Minutes	48 Minutes	7 Hours
9	Instantly	1 Minutes	11 Hours	2 Days	2 Weeks
10	Instantly	1 Hours	4 Weeks	6 Months	5 Years
11	Instantly	23 Hours	4 Years	38 Years	356 Years
...	...	...	...	...	...

# of Chars	Numbers Only	Lowercase Letters	Lower- & Uppercase Letters	Numbers, Upper- & Lowercase Letters	Numbers, Upper- & Lowercase Letters, Symbols
...	...	...	...	...	...
12	25 Seconds	3 Weeks	289 Years	2K Years	30K Years
13	3 Minutes	11 Months	16K Years	91K Years	2M Years
14	36 Minutes	49 Years	827K Years	9M Years	187M Years
15	5 Hours	890 Years	47M Years	613M Years	14Bn Years
16	2 Days	23K Years	2Bn Years	26Bn Years	1Tn Years
17	3 Weeks	812K Years	539.72M Years	2Tn Years	95Tn Years
18	10 Months	22M Years	7.23Bn Years	96Tn Years	6Qn Years

> —2023: Home Security Heroes

Auf der Webseite https://www.securityhero.io/ai-password-cracking/ wird ein Tool angeboten, das eine Schätzung vornimmt wie lange eine AI braucht, um das Passwort zu knacken.

Empfohlene Tests:

- start
- Start
- StartStart
- startstart!

Wie bewerten Sie die Einschätzungen dieses Tools?

Passwort Leaks

Check Your Accounts: 10 Billion Passwords Exposed in Largest Leak Ever

The "RockYou2024" database includes almost 10 billion passwords pulled from a mix of old and new data breaches. Here's how to check if yours are at risk.

[...]Researchers at Cybernews have uncovered a massive trove of nearly 10 billion passwords on a popular hacking forum in what they're calling "largest password compilation" ever.

The file, titled `rockyou2024.txt`, was posted on July 4 by someone going by the name Obama-Care and contains a mind-boggling 9,948,575,739 unique plaintext passwords. The user only joined the forum in late May, but they've posted data from other breaches, too. [...]

—6. Juli 2024: PCMag

Raum der Passwortkandidaten

vierstellige PIN: 10.000 Kombinationen

> ⚠ Warnung
>
> Eine vierstellige PIN kann niemals als sicher angesehen werden. Selbst wenn ein Bruteforce nur auf 4 oder 5 Versuche pro Stunde kommt, so ist es dennoch in wenigen Monaten möglich die PIN zu ermitteln.

Passwort mit 8 Zeichen und 70 Zeichen im Zeichensatz (a-z, A-Z, 0-9 und ausgewählte Sonderzeichen):

$70^8 = 576.480.100.000.000 \approx 5{,}7 \times 10^{14}$ Kombinationen

Passphrase mit 6 Wörtern aus einem Wörterbuch mit 2.000 Wörtern:

$2.000^6 = 6{,}4 \times 10^{19}$ Kombinationen

Passphrase mit 4 Wörtern aus einem Wörterbuch mit 100.000 Wörtern:

$100.000^4 = 1 \times 10^{20}$ Kombinationen

Passwort mit 16 Zeichen und 84 Zeichen im Zeichensatz (a-z, A-Z, 0-9 und die meisten Sonderzeichen):

$84^{16} = 6{,}14 \times 10^{30}$ Kombinationen

Qualität von Passworten

Wie ist die Qualität der folgenden Passwörter zu bewerten in Hinblick darauf, wie aufwändig es ist das Passwort ggf. wiederherzustellen:

1. `Donaudampfschifffahrt`
2. `Passwort`
3. `ME01703138541`
4. `2wsx3edc4rfv`
5. `Haus Maus`
6. `iluvu`
7. `Emily18`
8. `MuenchenHamburg2023!!!!`
9. `hjA223dn4fw"üäKßß k≤-~ajsdk`
10. `Baum Lampe Haus Steak Eis Berg`

Passwörter werden immer gehasht gespeichert.

Hashraten in MH/s auf aktueller Hardware

Hash-cat 6.2.6. Mode	Hash	RTX 1080-Ti (250 W)	RTX 2080-TI (260 W)	RTX 3090 (350 W)	RTX 4090 (450 W)	RTX 5090 (575 W)
25700	Murmur				643700.0 (643 GH/s)	819500.0 (819 GH/s)
23	Skype	21330.1	27843.1	37300.7	84654.8	116900.0
1400	SHA2-256	4459.7	7154.8	9713.2	21975.5	28353.3
10500	PDF1.4-1.6	24.9	29.8	76.8	122.0	166.4
1800	SHA 512 Unix (5000 Iterations)	0.2	0.3	0.5	1.2	1.4
13723	Veracrypt SHA2- 512 + XTX 1536Bit	0.0004	0.0006	0.0009	0.002 (2000 H/s)	0.002 (2278 H/s)

Quellen:

- 5090
- 4090
- 3090
- 2080Ti
- 1080Ti

✎ Diskussion

8.1. Schwachstellenbewertung

Ihnen liegt eine externe Festplatte/SSD mit USB Anschluss vor, die die folgenden Eigenschaften hat:

- Die Daten auf der SSD/FP sind hardwareverschlüsselt.
- Die Verschlüsselung erfolgt mit XTS-AES 256.
- Es gibt eine spezielle Software, die der Kunde installieren muss, um das Passwort zu setzen. Erst danach wird die Festplatte „freigeschaltet“ und kann in das Betriebssystem eingebunden werden. Davor erscheint die SSD/FP wie ein CD Laufwerk auf dem die Software liegt.
- Die SSD/FP ist FIPS zertifiziert und gegen Hardwaremanipulation geschützt; zum Beispiel eingegossen mit Epoxidharz.
- Das Passwort wird von der Software gehasht und dann als Hash an den Controller der externen FP/SSD übertragen.
- Im Controller wird der übermittelte Hash direkt zur Autorisierung des Nutzers verwendet. Dazu wird der Hash mit dem im EPROM hinterlegten verglichen.

Diskutieren Sie die Sicherheit der Passwortvalidierung und wie diese ggf. zu verbessern wäre.

Sichere Passwörter

- Nehmen Sie kein Passwort, dass 1:1 in einem Wörterbuch, Verzeichnis oder Leak (vgl. https://haveibeenpwned.com) vorkommt.
- Nehmen Sie keine Szenepasswörter (zum Beispiel: admin, root, acab, 1312, 88, ...).
- Je länger desto besser, aber keine trivialen Sätze.
- Wählen Sie ein Passwort, dass Sie sich merken können. Kombinieren Sie z. B. Dinge aus Ihrem privaten Umfeld, die aber niemand direkt mit Ihnen in Verbindung bringen kann. (D. h. die Namen Ihrer Kinder, Haustiere, etc. sind keine gute Wahl, aber ggf. das Modell Ihres Fernsehers in Kombination mit einer Pin und dem Namen Ihres ersten Smartphones getrennt durch ein paar Sonderzeichen).
- Verwenden Sie sichere Passwortmanager.

9. Zusammenfassung

Besprochene Themen

Schutzziele der IT-Sicherheit

Social-Engineering Angriffe

Cybersicherheit stärken

Schwachstellen und deren Bewertung

Eine erste Einführung in die Kryptographie

Passwortsicherheit